

UF6

Aseguramiento de la privacidad

Ciberseguridad

ÍNDICE

Introducción.....	05
Objetivos.....	06
Mapa conceptual	07
1. Administración y seguimiento de redes	08
1.1. Administración y seguimiento de servicios de red	08
A. Rango de direcciones IP	09
B. Dirección MAC: la clave para una IP estática segura.....	10
C. Puertos	10
D. Servicios de red activos	10
E. SNMP (protocolo simple de administración de red).....	12
1.2. Fraudes informáticos y robos de información: ingeniería social	12
A. Antivirus en red.....	13
B. Ingeniería social: el factor humano como punto débil	13
C. Phishing (pesca).....	13
D. Fraudes bancarios.....	14
E. Medidas contra el phishing.....	14
F. Seguridad adicional	14
G. Hoax (falsas alarmas)	15
H. Pharming (descaminamiento)	15
I. Cartas nigerianas.....	16
J. Scam baiting.....	16
K. Otras técnicas de ingeniería social y spam	16

1.3. Publicidad en Internet y el problema del spam	18
A. Publicidad no deseada: el problema del spam	18
B. Tipos de publicidad no deseada	20
C. Costes del spam	20
D. Medidas contra el spam	20
1.4. Redes de ordenadores: tipos, funcionamiento y seguridad.....	21
A. Funcionamiento interno de las redes	22
B. Monitorización legítima	23
C. Sniffing ilegítimo	23
1.5. Protección de redes wifi y sus estándares de comunicación	24
A. SSID (Service Set Identifier)	25
B. Autenticación por dirección MAC	25
C. Protocolos de seguridad wifi	26
1.6. Métodos de identificación: firma electrónica y certificado digital....	27
A. Certificado digital	28
B. Firma electrónica	29

2. Herramientas técnicas de defensa y gestión

de la seguridad en redes.....	32
2.1. Uso de herramientas de monitorización en redes.....	32
A. Alertas y niveles de funcionamiento	32
B. Análisis histórico y en tiempo real	34
C. Estado instantáneo de la red	34
D. Gestión y análisis de registros (logs)	35
2.2. Cortafuegos en equipos y servidores: instalación,	
configuración y buenas prácticas	36
A. Ámbito de protección del cortafuegos.....	36
B. Base del filtrado.....	37
C. Política por defecto	37
D. Filtrado por rango o por dirección IP	37
E. Tipos de bloqueo	38

F. Modos de configuración del cortafuegos	38
G. Funciones adicionales.....	38
H. Limitaciones de los cortafuegos.....	38
I. Cortafuegos en Linux	39
2.3. Interpretación y uso como soporte de documentación técnica	42
A. Fases de implementación segura de un sistema	42
B. Procedimientos operativos.....	43
C. Monitorización del sistema.....	44
D. Supervisión y monitores reactivos.....	44
2.4. Documentación de incidentes de seguridad	45
A. Descripción	46
B. Resumen.....	46
C. Análisis	47
D. Anexos	48
Solucionario casos prácticos	50
Enlaces de interés	56
Glosario.....	60
Bibliografía.....	63

Introducción

Vivimos en un mundo hiperconectado. Cada clic, cada búsqueda, cada mensaje deja una huella digital. Pero ¿quién protege esa información? ¿Quién se asegura de que tus datos —y los de millones de personas— no caigan en las manos equivocadas?

Te convertirás en el profesional que sabe proteger lo invisible. Descubrirás cómo las redes se configuran y supervisan, y aprenderás a detectar vulnerabilidades y a enfrentarte a amenazas reales como el phishing, el spam o los ataques a redes wifi. Dominarás el uso de herramientas como Nmap y sistemas de detección de intrusos. Protegerás redes wifi, configurarás servicios seguros y conocerás cómo la ingeniería social puede engañar hasta al más preparado. No solo se trata de adquirir conocimiento, sino también de aprender a anticiparse.

Hoy más que nunca, las empresas necesitan expertos capaces de garantizar la confianza digital.

Tu conocimiento marcará la diferencia entre una organización segura y una víctima más. Si sabes configurar bien los firewalls y documentar bien los informes de seguridad, estás salvaguardando algo más que datos.

Objetivos

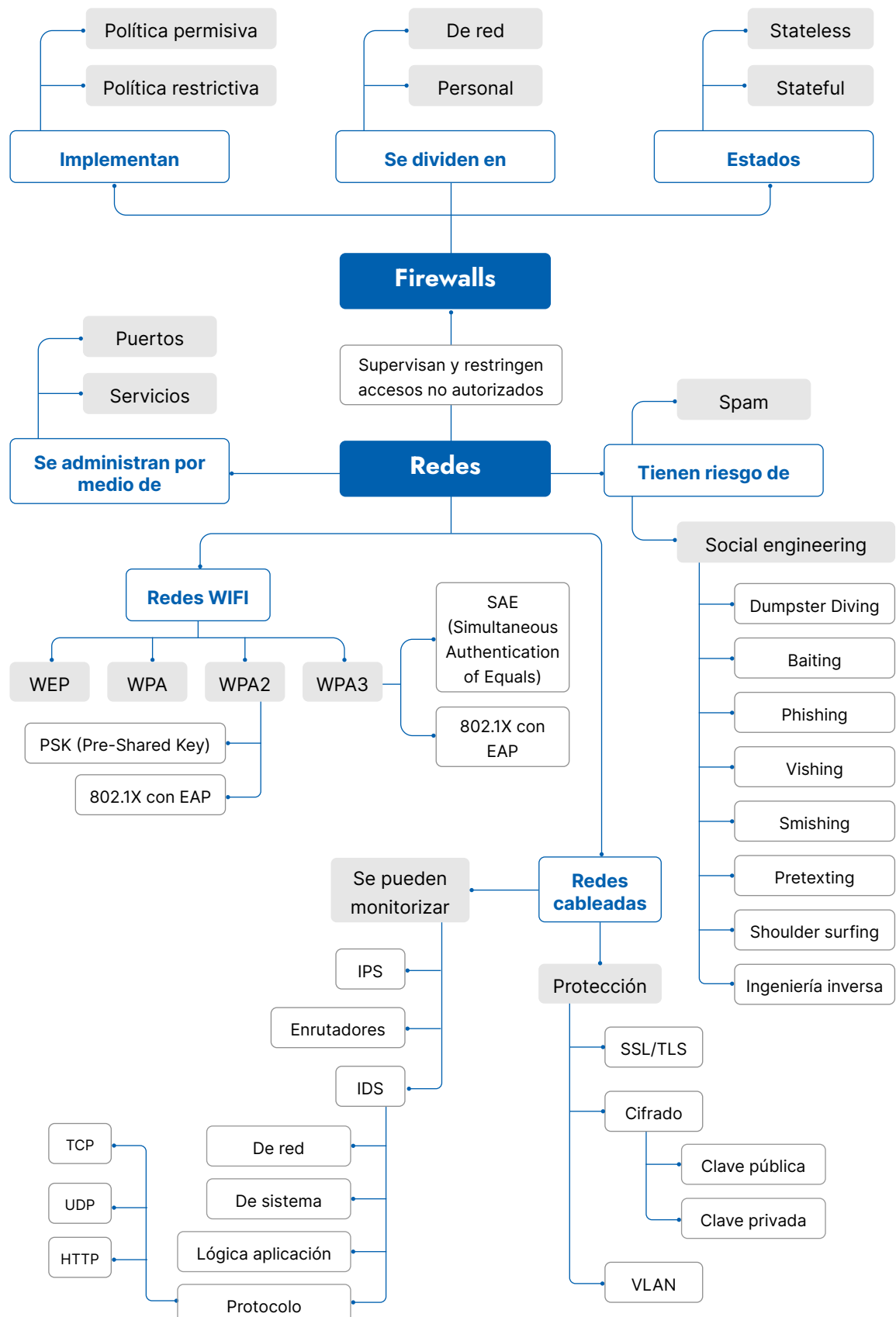
X

Comprender cómo se protegen los datos personales y confidenciales mediante cifrado, certificados digitales y firma electrónica; reconocer tipos de ataques como el phishing, la ingeniería social, el malware y el spam; aplicar medidas preventivas eficaces, y conocer los protocolos y la configuración de IP, puertos y servicios, así como saber controlar accesos y segmentar redes.

X

Aplicar herramientas como Nmap, Wireshark, Nagios o Zabbix para auditar, diagnosticar y proteger infraestructuras; aplicar buenas prácticas en la administración de sistemas, y establecer las políticas de seguridad, los procedimientos operativos y la documentación adecuada para entornos productivos.

Mapa conceptual



01 Administración y seguimiento de redes

Para asegurar un **nivel óptimo de calidad** de servicio en las redes, necesitamos de mecanismos adecuados para la monitorización y el control de este. Además, se requieren sistemas de control de acceso que lo permitan solo a usuarios autorizados, garantizando que estos utilicen la red según los términos establecidos por los administradores o responsables de su gestión.



¿SABÍAS QUE...?

Las redes transportan **paquetes de información** que contienen tanto datos de usuario (para aplicaciones y comunicación) como datos de control necesarios para su funcionamiento (encaminamiento, verificación de integridad, etc.). La monitorización de redes consiste en el conjunto de herramientas y mecanismos que analizan esta información para evaluar y garantizar el correcto funcionamiento de la infraestructura.

1.1. Administración y seguimiento de servicios de red

Una red informática está formada por un conjunto de **hardware y software interconectado**, ya sea a través de cables o mediante tecnologías inalámbricas como **Wi-Fi o Bluetooth**, entre otras. Hoy en día sería impensable vivir sin las redes, ya que nos permiten **compartir información y recursos**, lo que mejora la eficiencia de los procesos.

Las redes pueden variar en tamaño. Por ejemplo, las redes de ámbito local (**LAN-Local Area Network**) suelen consistir en unos pocos ordenadores, impresoras y otros recursos de uso personal. En cambio, las **redes corporativas** pueden ser mucho más complejas y abarcar extensas áreas geográficas.

En redes complejas, **una gestión adecuada es imprescindible** para asegurar su correcto funcionamiento, tanto en rendimiento como en seguridad.

Es fundamental tener control sobre **qué recursos forman parte de la red y cómo interactúan entre ellos**. Por ejemplo, en una multinacional, un empleado en una sede de Francia no debería tener acceso a una impresora en una sede de Portugal. Conocer los dispositivos conectados también facilita la **detección de intrusos no autorizados**.

Además, los administradores de red deben definir **qué servicios están permitidos** en cada caso. Hay redes en las que, por razones de productividad, **se bloquean las redes sociales, los juegos, los periódicos deportivos...** para evitar distracciones.

La configuración, el mantenimiento y la gestión de una red pueden resultar tareas complejas. Es necesario **monitorizar los equipos y servicios críticos, los usuarios, el rendimiento de la red y las posibles amenazas externas**.

Para gestionar una red de forma correcta, se deben tener en cuenta varios factores clave:

- » Rango de direcciones IP.
- » Inventario de direcciones MAC.
- » Puertos.
- » Servicios de red activos.
- » SNMP (Protocolo simple de gestión de red).

A. Rango de direcciones IP

Una dirección IP identifica un dispositivo dentro de una red. Está compuesta por **cuatro octetos**, generalmente representados por números del 0 al 255, por ejemplo: 10.23.56.250.

Los servicios de red utilizan las IP para enrutar la información entre dispositivos. En una misma red **no puede haber dos equipos con la misma IP**, ya que esto provocaría conflictos.

Existen rangos de IP reservados exclusivamente para uso interno (no públicos en Internet):

- » 10.0.0.0 ↔ 10.255.255.255
- » 172.16.0.0 ↔ 172.31.255.255
- » 192.168.0.0 ↔ 192.168.255.255

Los equipos dentro de una red interna usan estos rangos, pero, para comunicarse con el exterior, deben hacerlo mediante una IP pública, normalmente gestionada por el **router** mediante **NAT (traducción de direcciones)**.

Las direcciones IP pueden asignarse de forma **dinámica** (automática) o **estática** (manual):

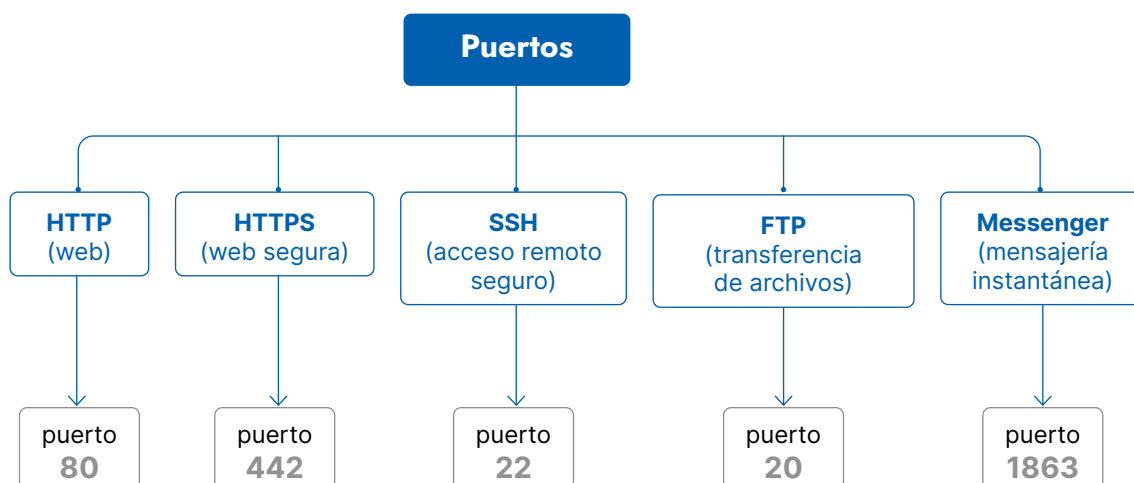
- » **Dinámicas:** utilizan protocolos como **DHCP**, que asigna automáticamente una IP disponible del rango cuando un dispositivo se conecta a la red.
- » **Estáticas:** asocian un dispositivo específico a una IP fija, lo que da **mayor control y previsibilidad**. Esto es útil para servidores o equipos críticos.

B. Dirección MAC: la clave para una IP estática segura

La **dirección MAC** es un identificador único asignado a cada interfaz de red, como una matrícula o un DNI. No existen dos dispositivos con la misma MAC. Una técnica para asignar IP estáticas es hacerlo según la MAC del dispositivo. Así, solo dispositivos autorizados podrán obtener una IP.

C. Puertos

Los protocolos de red como **TCP y UDP** utilizan **puertos** para establecer comunicaciones entre aplicaciones. Cada servicio usa un puerto específico. Por ejemplo:



Los administradores deben **controlar qué puertos están abiertos** y cuáles cerrados. **Tener puertos abiertos sin uso es un riesgo de seguridad**, ya que pueden ser explotados por los atacantes. Por tanto, la restricción y el control de puertos abiertos es una medida muy conveniente. Identifica tus necesidades y abre solo los puertos que necesites, reduciendo así significativamente el riesgo de ciberataques.

D. Servicios de red activos

En la red de una pequeña empresa, y mucho más en una red de grandes dimensiones, están funcionando muchos servicios al mismo tiempo. Algunos pueden ser específicos según el entorno, pero, en general, hay un conjunto de **servicios comunes** que se encuentran en la mayoría de los entornos.

Cada servicio utiliza un **puerto específico** para comunicarse. Si dos servicios intentan usar el mismo puerto, pueden producirse conflictos. Para evitar estos problemas, los puertos que usa cada servicio están **estandarizados** por la **IANA** (Internet Assigned Numbers Authority), la entidad encargada de asignar direcciones IP, nombres de dominio y puertos en Internet.

Los protocolos y puertos más utilizados son:

HTTP (HyperText Transfer Protocol)

Es el protocolo base de la web. Permite la transferencia de páginas web y funciona por el **puerto 80**. **No proporciona ningún tipo de cifrado o seguridad.**

HTTPS (HTTP Secure)

Es la versión segura del protocolo HTTP. Utiliza SSL/TLS para cifrar los datos, lo cual es fundamental para proteger información sensible, como datos bancarios o contraseñas. Funciona por el **puerto 443**.

SSH (Secure Shell)

Protocolo que permite acceder y administrar dispositivos de forma remota mediante conexiones cifradas. Muy utilizado por administradores de sistemas. Usa el **puerto 22**, aunque, en entornos de alta seguridad, se puede deshabilitar y permitir solo el acceso físico.

FTP (File Transfer Protocol)

Protocolo para transferir archivos entre dispositivos remotos. Se debe controlar qué usuarios tienen permiso para enviar o recibir archivos. Usa los **puertos 20 y 21** (el 20 para la transferencia de datos y el 21 para el control).

Mensajería instantánea

Algunas aplicaciones de mensajería utilizan puertos específicos. Aunque muchas empresas las usan como herramientas de comunicación interna, otras prefieren bloquear estos servicios por motivos de seguridad. Por ejemplo, antiguamente **MSN Messenger** usaba el **puerto 1863**. Sin embargo, muchas aplicaciones actuales (como WhatsApp Web, Slack o Microsoft Teams) usan **puertos como el 443 o el 80** para dificultar su bloqueo, ya que comparten puertos con servicios esenciales como HTTPS.

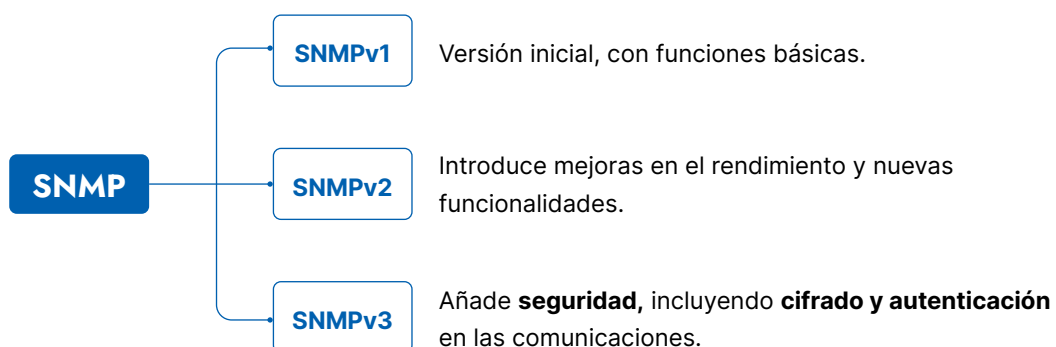
E. SNMP (protocolo simple de administración de red)

El **SNMP (Simple Network Management Protocol)** permite una gestión **remota, sencilla y centralizada** de los dispositivos de red, monitorizando el rendimiento, los errores y la disponibilidad.

Los elementos que conforman una red SNMP son:

- » **Dispositivos administrados:** cualquier equipo en la red (routers, switches, servidores, impresoras, etc.).
- » **Agentes SNMP:** software residente en los dispositivos, que recopila y transmite datos de funcionamiento.
- » **Sistemas administradores:** aplicaciones que centralizan la supervisión y la gestión de la red.

Existen tres versiones principales:



1.2. Fraudes informáticos y robos de información: ingeniería social

Una de las máximas más importantes en el ámbito de la seguridad es que la cadena siempre se rompe por el eslabón más débil.

Actualmente, los equipos informáticos incorporan cada vez más nuevas tecnologías, lo que, irónicamente, también abre **nuevas puertas a usuarios malintencionados** que pueden hacer un uso fraudulento de dispositivos que no les pertenecen.

Los sistemas operativos modernos suelen incluir cortafuegos básicos que pueden ser eficaces contra ciertos troyanos y gusanos. Además, la mayoría de los programas se actualizan automáticamente para corregir vulnerabilidades, y existen antivirus gratuitos para usuarios domésticos.

A. Antivirus en red

Para que un antivirus sea eficaz, es fundamental que actualice con frecuencia su base de datos de virus, ya que las amenazas evolucionan constantemente. Hoy en día, existen alternativas gratuitas como **Avast**, **Avg** o **Avira**, que permiten disponer de un antivirus actualizado de forma automática.

B. Ingeniería social: el factor humano como punto débil

A medida que a los hackers les resulta más difícil vulnerar los sistemas técnicos, recurren cada vez más a técnicas de **ingeniería social**, basadas en la premisa de que los usuarios son el eslabón más débil de la seguridad.

La ingeniería social no es exclusiva del ámbito informático. Desde hace siglos, existen estafas basadas en el engaño, como el **timo del tocomoch** o el de la **estampita**, que hoy tienen equivalentes modernos como el phishing o el pharming.

Desde el punto de vista de la seguridad informática, la ingeniería social es la práctica de obtener información confidencial manipulando o engañando a usuarios legítimos.

La información que los atacantes buscan suele ser de tipo bancario o de otros datos sensibles que les permitan acceder de forma ilegítima a los sistemas.

Podríamos decir que la ingeniería social se apoya en cuatro principios psicológicos:

- » A todos nos gusta ayudar a los demás.
- » Nos cuesta decir que no o crear conflictos.
- » Tendemos a confiar en la primera impresión.
- » A todos nos gusta recibir elogios.

C. Phishing (pesca)

El phishing consiste en usar herramientas informáticas para engañar al usuario mediante la **suplantación de identidad**. El término proviene del inglés *fish* (pescar), pero los hackers suelen escribirlo con «ph» como jerga propia. Algunos creen que también podría derivar de *password harvesting fishing* (pesca y recolección de contraseñas).

Se trata de hacer que el usuario muerda el anzuelo de un engaño. Aunque existen muchas formas de phishing, la más común es el **fraude bancario**.

D. Fraudes bancarios

A diferencia de hace unos años, hoy en día el uso de la banca online es común y, a medida que se ha ido popularizando, han ido apareciendo los ataques de phishing. El estafador envía un correo electrónico haciéndose pasar por una entidad financiera para solicitar datos confidenciales del usuario mediante una **web falsa** que imita a la original.

Un truco habitual es utilizar URL que se parecen a las legítimas, por ejemplo: www.mibanco.com, www.s4ntander.com o similares, lo que puede engañar fácilmente a un usuario poco atento.

Una vez que el usuario accede a esta web falsa, se le pide que introduzca datos sensibles como el usuario, el password o el número de tarjeta (CVV y fecha de caducidad). Si los atacantes logran estos datos, pueden suplantar su identidad y realizar compras u operaciones fraudulentas.

E. Medidas contra el phishing

La primera y más importante medida es la **educación y concienciación del usuario**. Muchos ataques pueden evitarse aplicando el sentido común:

- » Desconfiar de correos en idiomas que no usamos habitualmente o con muchas faltas ortográficas.
- » Sospechar si el mensaje no contiene datos personales.
- » No hacer clic en enlaces incluidos en correos sospechosos.
- » Introducir manualmente la dirección del banco en el navegador.

F. Seguridad adicional

- » **Doble factor de autenticación (2FA):** sustituye a las tarjetas de coordenadas tradicionales. Este sistema requiere una segunda verificación (como un código enviado por SMS, una app como Google Authenticator o una clave biométrica), lo que impide el acceso incluso si el atacante conoce el usuario y la contraseña.
- » **Filtros de correo avanzados:** muchos servicios de correo electrónico (como Gmail u Outlook) incorporan filtros inteligentes que detectan intentos de phishing. Aunque no son infalibles, reducen considerablemente el riesgo.
- » **Simulacros de phishing internos:** algunas empresas realizan campañas de phishing simuladas, enviando correos falsos a sus empleados para evaluar su preparación. Esta práctica forma parte de la formación en ciberseguridad corporativa y permite reforzar las buenas prácticas.

- » **Navegadores con protección activa:** navegadores como Chrome, Firefox o Edge incorporan sistemas de detección de sitios fraudulentos y muestran advertencias si una web es sospechosa.
- » **Certificados digitales y conexiones HTTPS:** comprobar que la web usa una conexión segura (https://) y que el certificado SSL es válido es clave para evitar caer en sitios falsos.

G. Hoax (falsas alarmas)

Hoax significa literalmente «engaño». En ciberseguridad, se refiere a correos electrónicos con historias falsas que se difunden con la intención de ser reenviadas en cadena.

A veces buscan simplemente **viralidad**, y en otras ocasiones pretenden **obtener direcciones de correo**. Como las direcciones no están cifradas, pueden ser recopiladas y utilizadas para enviar spam o realizar phishing.

Las historias suelen tratar acerca de personas que necesitan ayuda urgente o sobre desastres naturales, o simplemente de eventos que puedan causar una alarma social.



CLAVES Y CONSEJOS

Antes de reenviar un correo masivo, es recomendable hacer una **búsqueda** en Internet para verificar si la historia es real.

H. Pharming (descaminamiento)

Es una técnica que redirige a los usuarios a una página falsa mediante la manipulación de los servidores DNS (Domain Name System), que se encargan de traducir direcciones como www.google.com a direcciones IP reales.

Si un DNS es manipulado mediante un ataque conocido como DNS poisoning, puede redirigir a los usuarios a sitios fraudulentos, aunque hayan escrito correctamente la URL. Afortunadamente, los sistemas DNS actuales son cada vez más robustos y estas vulnerabilidades se corrigen con rapidez, aunque el riesgo nunca desaparece del todo.

I. Cartas nigerianas

Conocidas también como **estafa 419** (por el artículo del código penal que infringen), estas cartas prometen a la víctima grandes sumas de dinero si colabora en operaciones de blanqueo. Una versión común es la del supuesto banquero que afirma que una persona con el mismo apellido ha muerto dejando una herencia millonaria sin herederos. Si la víctima acepta colaborar, se le pide dinero para avanzar los trámites. Algunas víctimas incluso viajan al país del estafador, lo que puede llegar a ser extremadamente peligroso. Aunque esta estafa existe desde antes de Internet —originalmente por correo postal—, sigue vigente hoy en día por correo electrónico.

J. Scam baiting

Algunas personas, llamadas scam baiters, se dedican a engañar a los estafadores fingiendo ser víctimas para hacerles perder tiempo y recursos.

K. Otras técnicas de ingeniería social y spam

Además del phishing, el hoax, el pharming y las cartas nigerianas, existen muchas otras técnicas de ingeniería social que los ciberdelincuentes utilizan para engañar a los usuarios. Estas son algunas de las más comunes y actuales:

Spear Phishing (phishing dirigido)

Es una variante más sofisticada del phishing tradicional. En lugar de enviar un mensaje genérico a miles de personas, el atacante investiga a una persona o grupo específico (por ejemplo, empleados de una empresa) y personaliza el mensaje para que sea más convincente. Suele incluir datos reales del objetivo (nombre, cargo, relaciones laborales), lo que aumenta la probabilidad de éxito.

Whaling (ataque a peces gordos)

Es un tipo de spear phishing enfocado en objetivos de alto perfil como directivos, CEO o responsables financieros. El atacante se hace pasar por una figura importante (un proveedor, un socio o incluso otro directivo) para obtener información sensible o transferencias de dinero.

Smishing (SMS phishing)

Similar al phishing, pero empleando como canal un mensaje SMS. El mensaje puede contener un enlace malicioso o un número de teléfono fraudulento. A menudo, el atacante se hace pasar por una empresa de mensajería, un banco o una entidad de cobro de deudas.

Vishing (voice phishing)

Se trata de engaños por teléfono. El atacante llama a la víctima fingiendo ser del banco, una entidad gubernamental o una empresa conocida, y la convence para que revele información confidencial o realice una acción, como transferir dinero.

Pretexting (pretextos falsos)

El atacante se inventa una historia o personaje (pretexto) para obtener acceso a la información o a los sistemas. Por ejemplo: hacerse pasar por el departamento de TI para pedir credenciales, o como proveedor que necesita acceso urgente.

Quid pro quo (algo a cambio)

El atacante ofrece un beneficio o servicio a cambio de información. Por ejemplo: ofrecer asistencia técnica gratuita o acceso a una herramienta premium a cambio de instalar software o compartir credenciales.

Baiting (uso de cebos)

Consiste en atraer a la víctima con algo deseable (una descarga gratuita, un archivo llamativo o un dispositivo USB supuestamente olvidado) que, al abrirse o conectarse, instala malware o captura información.

Shoulder Surfing (mirar por encima del hombro)

Aunque más tradicional, sigue siendo una técnica efectiva. El atacante observa físicamente a la víctima mientras introduce su contraseña, su código PIN o información confidencial, ya sea en una oficina, un cajero automático o un transporte público.

Malvertising (publicidad maliciosa)

El atacante coloca anuncios maliciosos en webs legítimas. Al hacer clic, la víctima puede ser redirigida a sitios fraudulentos, descargar malware o caer en trampas de phishing.

Spam Zombie Networks (botnets)

Algunos equipos infectados con malware se convierten en parte de una red de zombis controlada remotamente. Estas redes envían millones de correos de spam o phishing, o, entre otras actividades, minan criptomonedas desde equipos aparentemente legítimos, lo que dificulta su detección.

1.3. Publicidad en Internet y el problema del spam

Podríamos definir la **publicidad** como una herramienta utilizada para dar a conocer productos o servicios a futuros consumidores. Es una técnica antigua que ha ido evolucionando con los años para seguir atrayendo a usuarios potenciales del producto o servicio que se publicita. En sus inicios, la publicidad se realizaba de forma oral. Con la llegada de los medios de comunicación como la prensa, la radio y la televisión, se logró aumentar el número de receptores de los mensajes. Es importante reseñar que este tipo de medios tienen un gran negocio con la publicidad, que representa una de sus principales fuentes de ingresos.

La llegada de **Internet** revolucionó el mundo publicitario. Los costes son bastante más bajos que en los medios tradicionales, lo cual facilita que más anunciantes puedan participar. Además, gracias al análisis de datos y hábitos de navegación, es posible personalizar los anuncios para que se ajusten a los intereses específicos de cada usuario, cosa que no ocurre, por ejemplo, con la radio o los periódicos.

Hoy en día, la publicidad en Internet mueve enormes cantidades de dinero. Empresas como Alphabet (Google) obtienen más ingresos por publicidad online que Microsoft por la venta de Windows, aunque está por ver cómo evoluciona todo el tema de la publicidad con la inteligencia artificial generativa.

A. Publicidad no deseada: el problema del spam

Aunque la publicidad en sí misma no es ilegal, la **publicidad no solicitada o ilícita**, especialmente en entornos digitales, representa un problema molesto. A diferencia de los medios tradicionales, Internet es un entorno abierto y con bajos niveles de regulación, lo que facilita la propagación de anuncios no deseados.

Sería impensable emitir un **anuncio sin autorización** en televisión o radio, ya que estos son medios regulados. Sin embargo, en Internet es algo bastante sencillo. Un ejemplo clásico de publicidad no deseada fuera de la red sería el envío masivo de folletos publicitarios a los buzones de casa. En el mundo digital, los costes son aún menores, factor que facilita ese uso masivo sin grandes problemas.

Spam es el nombre que se le da a cualquier tipo de comunicación electrónica no deseada, como emails, SMS o anuncios invasivos. El término proviene de una marca de carne enlatada muy popular en Inglaterra, mencionada en un famoso sketch de los Monty Python, en el que se repetía constantemente sin que nadie lo pidiera, lo que reflejaba bien el concepto de publicidad no deseada.



¿SABÍAS QUE...?

A mediados de los **años 90**, con el aumento de usuarios de Internet, el spam comenzó a crecer de forma exponencial. En aquel entonces, el spam llegó a representar más del 85 % del tráfico global de correos electrónicos. Por suerte, gracias a la implementación de filtros antispam más efectivos y a una mayor concienciación de los usuarios, esta proporción ha ido disminuyendo en los últimos años. Actualmente, se estima que aproximadamente el 50 % de todos los correos electrónicos a nivel mundial es spam. Aunque es un porcentaje importante, representa una mejora notable en comparación con décadas anteriores. Es importante destacar que, aunque la proporción de spam ha disminuido, el número total de correos electrónicos enviados diariamente ha aumentado. Por ejemplo, en **2024** se enviaron más de 162 mil millones de correos electrónicos de spam cada día.

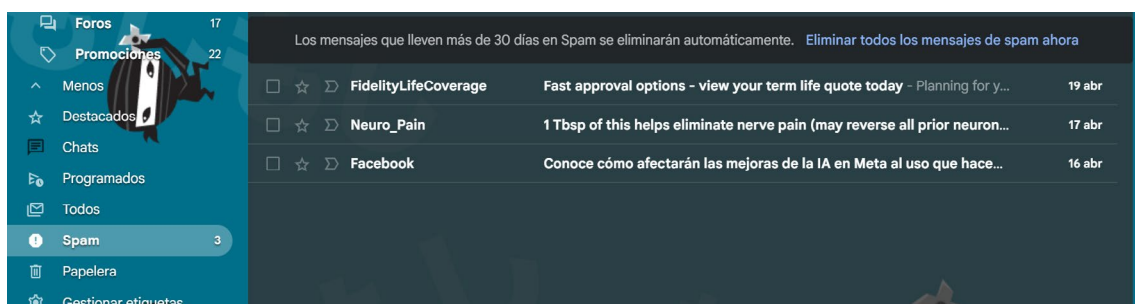


Fig. 1. Filtro antispam de Google.

B. Tipos de publicidad no deseada

- » **Correo electrónico:** es el método más utilizado por los spammers. Es rápido, barato y fácil de distribuir. La cantidad de spam supera con creces al correo legítimo.
- » **Ventanas emergentes (pop-ups):** mensajes que aparecen automáticamente al navegar por Internet. Utilizan funcionalidades del sistema operativo (como en versiones antiguas de Windows) para mostrar alertas no solicitadas. Pueden bloquearse con un firewall o desactivando esos servicios.
- » **Spim (spam por mensajería instantánea):** derivado de spam + IM (Instant Messaging), es la publicidad no deseada que llega por herramientas como WhatsApp, Telegram u otros chats.
- » **Spamdexing:** es la manipulación de los resultados en buscadores para dirigir tráfico a sitios con publicidad engañosa. Se basa en falsear el contenido indexado por motores de búsqueda como Google.
- » **Otros métodos:** también se propaga spam mediante comentarios en blogs, foros, wikis o chats de videojuegos, buscando siempre aprovechar espacios visibles.

C. Costes del spam

El correo no deseado genera **grandes costes tecnológicos y humanos:**

- » Saturación de redes y servidores.
- » Pérdida de tiempo para usuarios al filtrar mensajes legítimos de los que no lo son.
- » Desarrollo y mantenimiento de filtros antispam.
- » Uso de computadoras infectadas (zombies) para enviar spam sin el conocimiento del usuario.

D. Medidas contra el spam

Aunque es difícil erradicarlo, existen medidas de prevención y defensa:

- » **No responder nunca al spam:** hacerlo confirma que tu correo está activo.
- » **No aceptar confirmaciones de lectura:** también indican que el correo está en uso.
- » **No hacer clic en imágenes o enlaces de correos sospechosos:** pueden activar rastreadores.
- » **Controlar a quién se le da el correo electrónico:** compartirlo solo con fuentes de confianza.

- » **Usar cuentas diferentes para distintos fines:** una para contactos personales y otra para registros en sitios públicos.
- » **Crear direcciones poco predecibles:** evita nombres comunes o combinaciones fáciles de adivinar.
- » **No publicar la dirección de correo en texto plano:** mejor como imagen o usando técnicas para dificultar su detección por robots.

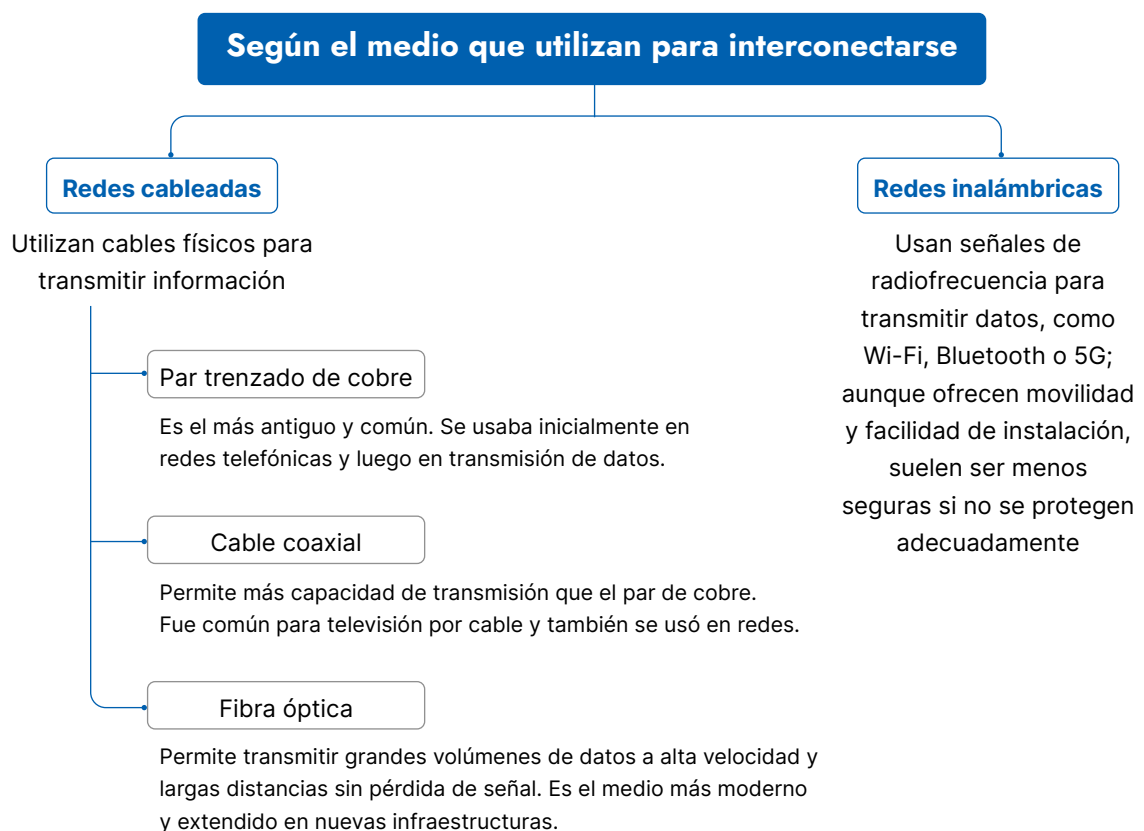
1.4. Redes de ordenadores: tipos, funcionamiento y seguridad

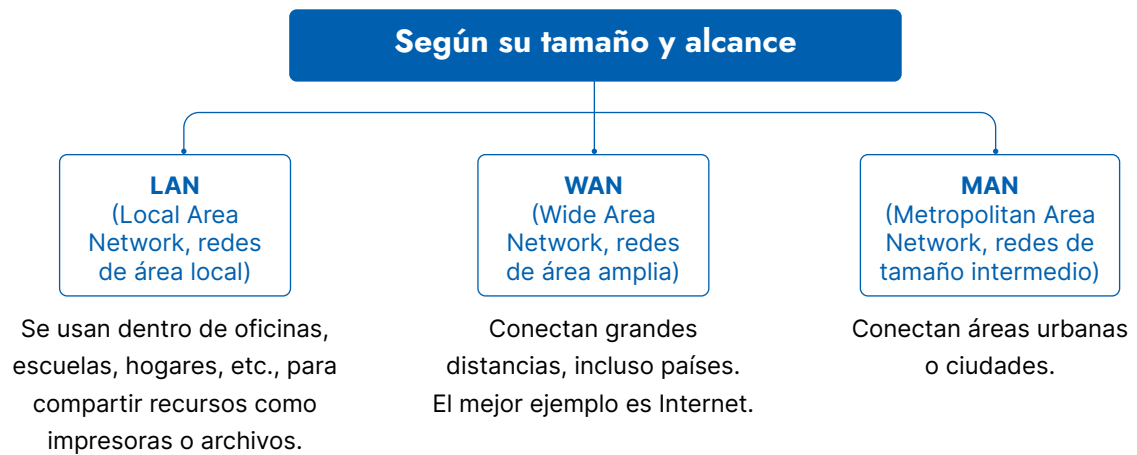
Hoy en día, todo el mundo conoce Internet como la Red, pero en realidad existen muchos otros tipos de redes de ordenadores.

Se puede definir una **red de ordenadores** como un conjunto de dispositivos interconectados que permite el intercambio de información y recursos.

Las primeras redes surgieron en la década de 1960. En 1969, la Universidad de California y la Universidad de Utah se conectaron a través de lo que sería el origen de ARPANET (Advanced Research Projects Agency Network), la red precursora de lo que hoy conocemos como Internet. Fue una red desarrollada por el Departamento de Defensa de EE. UU. con fines de investigación que a lo largo de los años evolucionó hasta convertirse en la actual Internet.

Las redes pueden clasificarse de la siguiente manera:





IMPORTANTE

Las redes cableadas, por lo general, ofrecen mayor estabilidad y seguridad que las inalámbricas, ya que el acceso físico a los cables es más difícil para un atacante. Sin embargo, **ninguna red está completamente libre de amenazas.**

A. Funcionamiento interno de las redes

Las redes están estructuradas en **capas lógicas** que organizan y gestionan el flujo de información. Este modelo se conoce como **modelo OSI (Open Systems Interconnection)**, creado por la ISO.

Las siete capas del modelo OSI son las siguientes:

- » **Capa física:** transmite los bits por el medio físico (cables, fibra...).
- » **Capa de enlace de datos:** asegura la conexión entre dos dispositivos conectados directamente.
- » **Capa de red:** encaminamiento y direccionamiento de los paquetes (p. ej.: IP).
- » **Capa de transporte:** asegura la entrega correcta de los datos (p. ej.: TCP/UDP).
- » **Capa de sesión:** gestiona el inicio, el mantenimiento y el cierre de la comunicación.
- » **Capa de presentación:** se encarga del formato de los datos (compresión, cifrado).
- » **Capa de aplicación:** es donde interactúa el usuario (p. ej.: navegadores, apps de correo).

Cada capa utiliza protocolos específicos y añade información a los datos para que los dispositivos de red puedan procesarlos correctamente.

En una red circula no solo la información del usuario, sino también datos necesarios para su funcionamiento. Existen dos enfoques clave: la monitorización (legítima) y el sniffing (ilegítimo).

B. Monitorización legítima

Permite que los administradores detecten errores, mejoren el rendimiento o localicen amenazas.

Los dispositivos clave son:

- » **Enrutadores (routers):** deciden la mejor ruta para enviar los datos.
- » **Cortafuegos (firewalls):** bloquean o permiten paquetes según reglas definidas.
- » **Sistemas de detección de intrusos (IDS):** analizan el tráfico para identificar posibles ataques.
- » **Sistemas de monitorización:** evalúan el estado de la red (p. ej.: hacen ping a servidores y envían alertas si hay problemas).

C. Sniffing ilegítimo

Los **sniffers** o analizadores de paquetes pueden capturar información que circula por la red. Si se usan con malas intenciones, permiten obtener contraseñas, datos bancarios o información confidencial. Algunos sniffers también permiten **modificar los datos** en tránsito, lo que puede derivar en la suplantación de identidad o el robo de sesiones.

EJEMPLO

-
- » **Wireshark:** uno de los analizadores de red más conocidos y potentes. Es de código abierto y se utiliza tanto con fines educativos como profesionales para el análisis de tráfico.
 - » **Tcpdump:** herramienta de línea de comandos muy utilizada en entornos Linux/Unix para capturar paquetes.
 - » **Ettercap:** especializado en ataques de tipo Man-in-the-Middle (MitM). Puede capturar y modificar tráfico en redes locales.
-

La mejor defensa es el **cifrado**, que impide que un atacante pueda leer la información sin tener la clave adecuada.

Los principales mecanismos de cifrado son:

- » **Cifrado de archivos y correos (p. ej.: PGP):** protege mensajes individuales. Requiere acción manual, lo que lo hace poco práctico a gran escala.
- » **SSL/TLS (Secure Socket Layer/Transport Layer Security):** crea un canal seguro entre el usuario y el servidor. Es lo que usan las páginas web **HTTPS**. Además de cifrar, también garantiza la autenticidad del servidor mediante **certificados digitales**.
- » **VPN (Virtual Private Network):** crea un túnel cifrado entre dos puntos de una red pública. A diferencia del SSL, cifra **todo** el tráfico, no solo las páginas web.

1.5. Protección de redes wifi y sus estándares de comunicación

A diferencia de hace unos años, las **redes inalámbricas** se han vuelto de uso cotidiano, tanto en entornos domésticos como empresariales, gracias a sus ventajas en **movilidad, flexibilidad y facilidad de instalación**. Frente a las redes con cables, las inalámbricas utilizan **ondas electromagnéticas** para transmitir los datos mediante radiofrecuencia, lo que nos permite enviar grandes volúmenes de información sin necesidad de cables físicos.

Se puede decir que el funcionamiento de una red wifi es similar al de las ondas de radio tradicionales, aunque **opera a frecuencias mucho más altas**, lo cual posibilita transmitir datos a mayor velocidad.

Una red inalámbrica no está separada: **intercambia datos con redes cableadas** para permitir el acceso a contenidos y servicios. Se necesita un dispositivo para realizar esta tarea, el **punto de acceso (AP)**, que conecta la red inalámbrica con la red cableada. Los diferentes dispositivos (ordenadores, móviles, tablets, dispositivos IoT [Internet of Things]) se conectan al AP, que los **autentica y gestiona el tráfico de red**.

- » **Puntos de acceso:** utilizan **antenas** para distribuir la señal en un área determinada, cuyo **alcance suele estar entre 30 y 150 metros**, dependiendo del tipo de antena, los obstáculos físicos y la potencia del dispositivo. A más potencia, más alcance. Si necesitamos cubrir un área extensa, se tendrán que desplegar **varios puntos de acceso** formando una malla que garantice una cobertura completa.

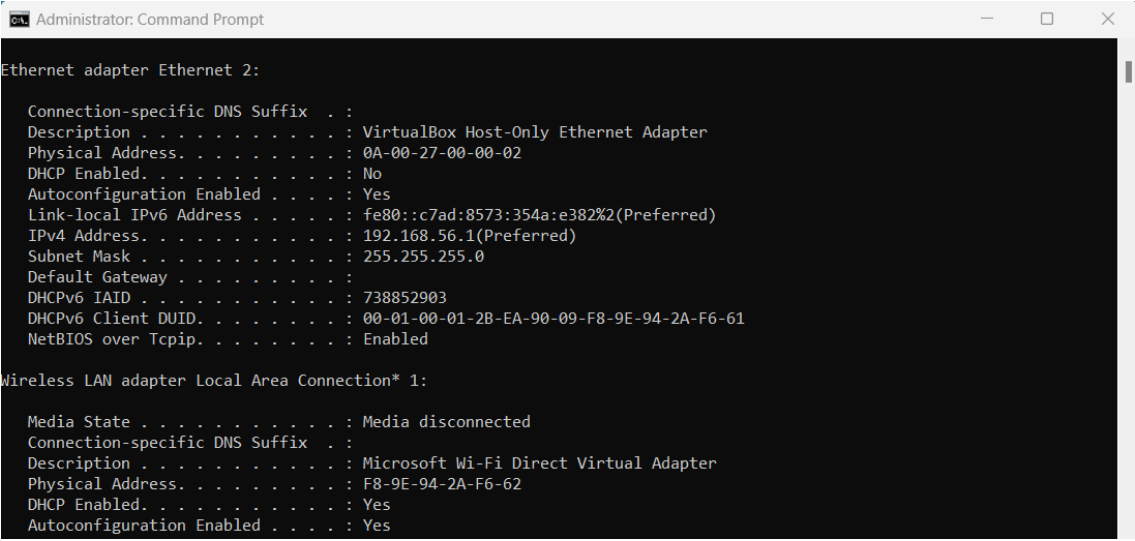
- » **Redes ad-hoc:** es un tipo de red inalámbrica descentralizada en la que los dispositivos se comunican directamente entre sí sin necesidad de un punto de acceso central, como un router. Se utiliza comúnmente cuando las redes basadas en infraestructura tradicional no están disponibles o son poco prácticas, como en situaciones de emergencia o en colaboraciones temporales.
- » **Seguridad en redes inalámbricas:** a pesar de las múltiples ventajas que ofrecen, las redes wifi son más vulnerables (**riesgos de seguridad**) que las redes cableadas. En una red con cables, un atacante necesita **acceso físico** al cableado. En cambio, en las inalámbricas, las señales van por el aire (**atraviesan paredes y ventanas**), y pueden ser interceptadas desde el exterior, incluso usando **antenas direccionales**.

A. SSID (Service Set Identifier)

El **SSID** es el nombre que identifica una red inalámbrica. Cada punto de acceso emite su SSID, que aparece al buscar redes disponibles. Es posible configurar el punto de acceso para **ocultar el SSID**, pero hay herramientas que pueden descubrirlo analizando el tráfico de la red.

B. Autenticación por dirección MAC

Cada dispositivo de red tiene una **dirección MAC única**, como un DNI. Es posible configurar una red para que solo acepte dispositivos con direcciones MAC autorizadas. Sin embargo, esta medida es **fácil de vulnerar mediante la técnica de MAC spoofing**, que consiste en cambiar la dirección MAC de un dispositivo. Esto puede hacerse manualmente introduciendo la nueva dirección MAC en la configuración del dispositivo. También se pueden utilizar algunos programas para cambiar automáticamente la dirección MAC. Una vez cambiada la dirección MAC, el dispositivo tendrá una identidad nueva.



```
Administrator: Command Prompt

Ethernet adapter Ethernet 2:

    Connection-specific DNS Suffix . . . : 
    Description . . . . . : VirtualBox Host-Only Ethernet Adapter
    Physical Address. . . . . : 0A-00-27-00-00-02
    DHCP Enabled. . . . . : No
    Autoconfiguration Enabled . . . . : Yes
    Link-local IPv6 Address . . . . . : fe80::c7ad:8573:354a:e382%2(Preferred)
    IPv4 Address. . . . . : 192.168.56.1(Preferred)
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 
    DHCPv6 IAID . . . . . : 738852903
    DHCPv6 Client DUID. . . . . : 00-01-00-01-2B-EA-90-09-F8-9E-94-2A-F6-61
    NetBIOS over Tcpip. . . . . : Enabled

Wireless LAN adapter Local Area Connection* 1:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix . . . : 
    Description . . . . . : Microsoft Wi-Fi Direct Virtual Adapter
    Physical Address. . . . . : F8-9E-94-2A-F6-62
    DHCP Enabled. . . . . : Yes
    Autoconfiguration Enabled . . . . : Yes
```

Haciendo un **ipconfig/all** en vuestro CMD podéis ver la MAC de vuestros dispositivos de red.

C. Protocolos de seguridad wifi

WEP (Wired Equivalent Privacy)

Fue el **primer protocolo de seguridad wifi**, diseñado para ofrecer privacidad similar a las redes cableadas. Sin embargo, su algoritmo (RC4) **era vulnerable**, y hoy en día **puede romperse con facilidad**. Aunque aún existen dispositivos que usan WEP, **está completamente desaconsejado** desde 2004.

OSA (Open System Authentication)

Acceso sin verificación real, muy inseguro.

SKA (Shared Key Authentication)

clave compartida entre el punto de acceso y el usuario. Aunque la conexión está cifrada, es fácil de romper.

WPA (Wi-Fi Protected Access)

Diseñado como mejora del WEP. Introduce los siguientes mecanismos más robustos de autenticación y cifrado.

WPA-PSK (Pre-Shared Key)

Clave compartida previamente, de entre 8 y 63 caracteres. La seguridad depende de la fortaleza de la contraseña.

802.1X

Autenticación centralizada mediante servidores, usada en entornos corporativos. Compatible con certificados digitales, Kerberos, etc.

TKIP (Temporal Key Integrity Protocol)

Genera claves temporales dinámicas, dificultando los ataques.

WPA2

Sucesor del WPA, **reconocido durante años como el estándar de referencia**. Usa el algoritmo **AES (Advanced Encryption Standard)** para cifrar datos, siendo considerado uno de los más seguros. Requiere **hardware compatible** para su funcionamiento completo.

WPA3

Aunque WPA3 se estableció como estándar en 2018 y es obligatorio para nuevos dispositivos desde 2020, aún se espera una adopción mucho más amplia y su consolidación en la mayoría de dispositivos y redes. Además, se prevén las siguientes mejoras y revisiones.

Implementación de WPA3-Enterprise con cifrado de 192 bits para entornos corporativos críticos.

Refuerzo del protocolo SAE para mitigar ataques avanzados como side-channel o downgrade.

Mejor compatibilidad con dispositivos IoT, manteniendo la seguridad en equipos con recursos limitados.

Actualizaciones para responder a nuevas vulnerabilidades wifi, como variantes extendidas del ataque KRACK.

Estas revisiones buscan mantener y mejorar la seguridad wifi frente a amenazas emergentes.

1.6. Métodos de identificación: firma electrónica y certificado digital

Internet ha contribuido de manera significativa a la globalización de nuestras vidas, hecho que ha provocado que se convierta en una herramienta totalmente necesaria e imprescindible para la mayoría de las empresas.

No obstante, la conexión a Internet lleva implícito un **riesgo de seguridad** para el sistema informático de la empresa. Esto ha llevado a los administradores de red a la necesidad de establecer políticas de seguridad que permitan crear conexiones seguras y garantizar el envío y la recepción de información cifrada, así como implementar filtros de acceso y control de datos, entre otras medidas de protección.

Dentro de este problema genérico de seguridad está la **privacidad** de los datos. Hasta ahora, no había ninguna protección real que garantizara que los mensajes que se envían o se reciben no fueran interceptados, leídos o, incluso, alterados por algún desconocido, puesto que realmente no hay nadie que dirija o controle la red de Internet. Este hecho provoca que se planteen posibles preguntas como: ¿sabemos si una persona tiene, efectivamente, una cuenta válida? o ¿sabemos si se puede confiar en una tienda online que no hemos visitado nunca?, entre muchas otras.

Para que la privacidad y la seguridad tengan la relevancia que les corresponde en Internet, cada entidad necesita disponer de una manera de verificar la identidad de las otras y poder establecer, así, un nivel de **confianza**. El certificado digital y la firma electrónica son algunas de las herramientas que permiten establecer conexiones seguras entre las personas y las administraciones. Además, ofrecen la posibilidad de hacer transacciones comerciales.

A. Certificado digital

Los **certificados digitales** son clave en la seguridad de las transacciones electrónicas de hoy en día, ya que nos proporcionan un método seguro y fiable para disfrutar de comunicaciones digitales confiables. Esta confianza se basa en la intervención de **autoridades de certificación (CA)**, que verifican la identidad de los solicitantes y emiten los certificados digitales correspondientes.

Para obtener un certificado digital, el usuario tiene que acudir a una **autoridad certificadora**, identificarse de forma correcta y, una vez verificada su identidad, recibir el certificado digital. A continuación, al enviar mensajes que lo requieran, basta con autenticar el certificado digital. De este modo, el receptor puede verificar correctamente la identidad del remitente, lo que resulta esencial en comunicaciones con empresas, Administraciones públicas y otros entornos de confianza.

Estos certificados utilizan cifrados criptográficos que garantizan **la confidencialidad, la integridad y la autenticidad** de la información transmitida, aspectos esenciales tanto para usuarios individuales como para empresas.

El proceso de cifrado consiste en transformar un mensaje en un código ilegible mediante el uso de una clave. Esto lo conocemos como **encriptación**, que transforma la información para que solo el destinatario autorizado pueda entenderla.

Actualmente, se pueden clasificar los certificados digitales en diferentes categorías:

- » **Certificados de servidor (SSL/TLS):** garantizan la seguridad de las conexiones web mediante el cifrado seguro de datos en tránsito.
- » **Certificados Microsoft Server Gated Cryptography (SGC):** una extensión del protocolo SSL que proporciona Microsoft para entornos específicos.
- » **Certificados de canal seguro:** protegen las comunicaciones en canales específicos, como VPN o túneles de comunicación.
- » **Certificados de correo electrónico (S/MIME):** permiten firmar y cifrar correos electrónicos para garantizar su autenticidad y confidencialidad.
- » **Certificados de autenticación de sitios web:** verifican la legitimidad de las páginas web, protegiendo contra la suplantación de identidad (phishing).
- » **Certificados de sello de tiempo (timestamp):** garantizan la validez de documentos digitales mediante un sello de fecha y hora confiable.

Los cifrados de clave **secreta (simétrica)** utilizan una clave tanto para el proceso de cifrado como para el proceso de descifrado. Para este tipo de sistemas, cada usuario debe tener acceso a la misma clave privada. Las claves privadas pueden compartirse a través de un canal de comunicación seguro previamente establecido, como un servicio de mensajería privado o una línea segura, pero hoy en día esto resulta poco práctico.

Para solucionar las limitaciones de un canal seguro para intercambiar la clave secreta, se desarrolló una solución conocida como **cifrado de clave pública (asimétrica)**. Este sistema, introducido en la década de 1970, utiliza dos claves diferentes pero complementarias.

B. Firma electrónica

DEFINICIÓN

La **firma electrónica** es, como seguramente habrás adivinado, otro componente crítico en un certificado digital. Junto con los datos del usuario y la clave pública, un certificado digital se utiliza para garantizar al receptor la identidad del autor de un mensaje. En otras palabras, proporciona mecanismos para que el receptor pueda verificar la autenticidad del documento, impide que el autor pueda repudiar su creación y garantiza que el contenido del mensaje no pueda ser alterado sin ser detectado.

Por ejemplo, cuando un usuario A envía un mensaje a un usuario B, puede cifrarlo junto con su certificado digital. Opcionalmente, el mensaje puede ser protegido con la clave pública del usuario B, lo que se conoce como **firma digital**. Este proceso garantiza que nadie pueda modificar el contenido del mensaje sin invalidar el certificado del emisor, lo que protege la integridad y la confidencialidad de la información que se transmite.

Estas firmas consisten en bloques de datos codificados mediante una clave privada y que pueden ser verificados con su clave pública. Su función principal es garantizar la autenticidad del mensaje o la validez de una clave pública, proporcionando un alto nivel de seguridad en las comunicaciones digitales.

En España, la **Ley 6/2020, de 11 de noviembre**, establece el marco legal actual para el uso de la firma electrónica, sustituyendo a la anterior **Ley 59/2003**. Esta ley define tres tipos principales de firma electrónica, para cumplir con el Reglamento eIDAS de la Unión Europea:

- » **Firma digital simple:** es el tipo más básico de firma digital y no está protegida por ningún método de encriptación. Es el equivalente electrónico de una firma húmeda escaneada o de una firma de correo electrónico.

- » **Firma digital avanzada:** está vinculada a firmantes específicos y proporciona un mayor nivel de seguridad que una firma digital simple. Utiliza estándares de infraestructura de clave pública (PKI) para proporcionar un alto nivel de seguridad y aceptación universal.
- » **Firma digital cualificada:** es el tipo más seguro de firma digital y requiere un nivel más riguroso de garantía de identidad a través de certificados digitales. Es legalmente vinculante en muchos países y tiene el mismo valor que las firmas manuscritas tradicionales.

El reglamento **eIDAS (Reglamento [UE] n.º 910/2014)** establece un marco normativo común en la UE para la firma electrónica, garantizando su reconocimiento mutuo entre los Estados miembros y proporcionando un marco de confianza para transacciones electrónicas seguras.

Con el uso masivo de Internet, las firmas digitales se han convertido en indispensables para los trámites en los que se requiere una mínima seguridad jurídica y la protección de datos.

Las redes inalámbricas son cómodas y versátiles, pero necesitan una **configuración segura**. Es imprescindible utilizar protocolos como **WPA2 o WPA3** y configurar contraseñas seguras (mayúsculas, minúsculas, caracteres especiales...), además de combinar otras medidas como la segmentación de red, el filtrado MAC y actualizaciones periódicas del firmware de los routers y puntos de acceso.

1

CASO PRÁCTICO

**AUDITORÍA BÁSICA DE SEGURIDAD INTERNA**

Eres el técnico de redes de una pequeña empresa que necesita realizar una auditoría básica de seguridad interna sobre uno de sus servidores. Para ello, se han preparado dos máquinas virtuales:

- » Ubuntu Server con IP fija 192.168.10.201, actuando como el servidor por analizar.
- » Ubuntu Desktop, tu equipo de trabajo, desde donde realizarás los escaneos y auditorías.

Ambas máquinas están conectadas a la misma red interna (192.168.10.0/24). Tu misión es:

- » Detectar dispositivos activos en la red.
- » Escanear puertos abiertos en el servidor.
- » Identificar los servicios que corren en esos puertos.
- » Intentar reconocer el sistema operativo del servidor.
- » Evaluar posibles riesgos y sugerir mejoras.

¿Qué sistema operativo detecta **nmap**? ¿El resultado parece fiable? Justifica tu respuesta.

02 Herramientas técnicas de defensa y gestión de la seguridad en redes

Existen muchísimos mecanismos para gestionar la seguridad en las redes. Uno de ellos consiste en el uso de **firewalls (cortafuegos)**, que permiten definir la visibilidad y el acceso entre los distintos equipos que componen la red. Otro es el software especializado, a través del que es posible monitorizar el estado de la red y detectar intentos de intrusión.

Aun así, en caso de que finalmente se produzca una intrusión, es fundamental contar con un procedimiento de actuación previamente definido, con el fin de evitar **daños mayores**, como la destrucción de evidencias o la repetición del ataque.

2.1. Uso de herramientas de monitorización en redes

Para un control completo de la red y los sistemas que la integran, es necesario utilizar un conjunto variado de herramientas. Estas permiten observar el comportamiento en diferentes situaciones: no es lo mismo detectar un ataque de denegación de servicio (DoS) que rastrear un **nmap** para un escaneo de puertos.

A. Alertas y niveles de funcionamiento

Es esencial contar con un sistema de alertas configurado adecuadamente que informe sobre fallos o ataques. Para ser eficaz, se deben evitar:

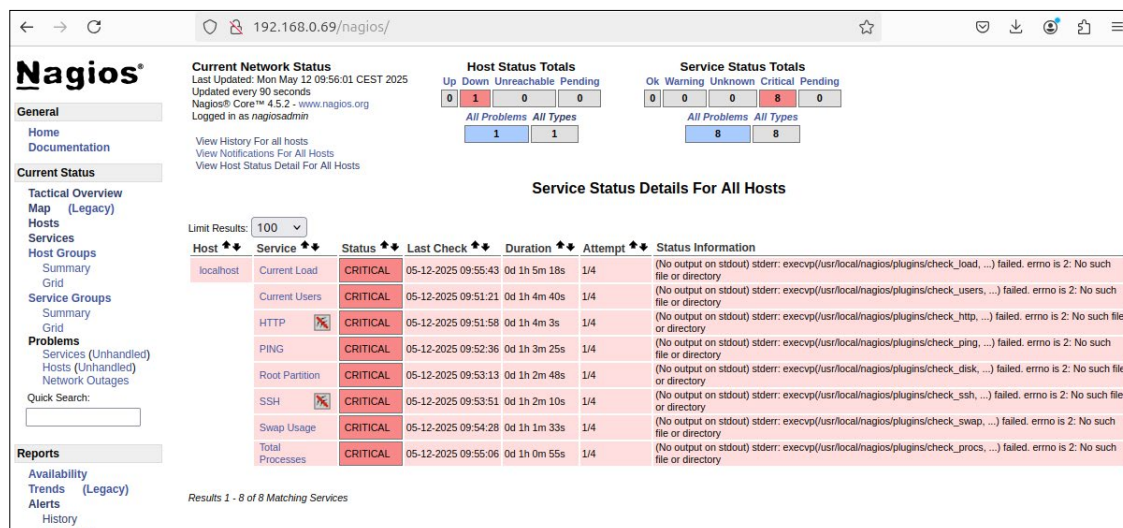
- » Falsos positivos (alertas incorrectas).
- » Falsos negativos (fallos no detectados).
- » Alertas masivas (un fallo que provoca cascadas de notificaciones).

Los niveles recomendados son:

- » **Correcto:** funcionamiento normal.
- » **Aviso:** desviación leve que podría provocar problemas.
- » **Alerta:** servicio degradado o inoperativo.

Para evitar alertas masivas se recomienda definir **dependencias** entre servicios y configurar chequeos que informen si un equipo está apagado en lugar de generar alertas por cada servicio caído.

- » **Nagios:** es una herramienta de código libre muy extendida para monitorizar servicios y sistemas.

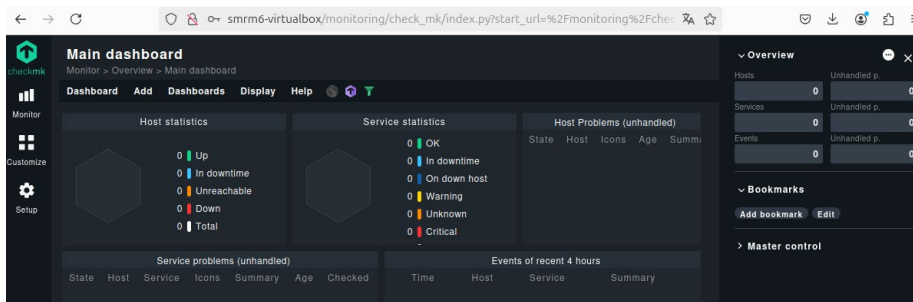


Aunque sigue siendo válida, existen alternativas que ofrecen interfaces más intuitivas y mayor escalabilidad, como:

- » **Zabbix:** monitorización completa con visualización avanzada y autodetección de hosts.



- » **Prometheus + Grafana:** ideal para entornos dinámicos como contenedores y Kubernetes.
- » **Checkmk:** evolución basada en Nagios, con configuración más sencilla y dashboards integrados.

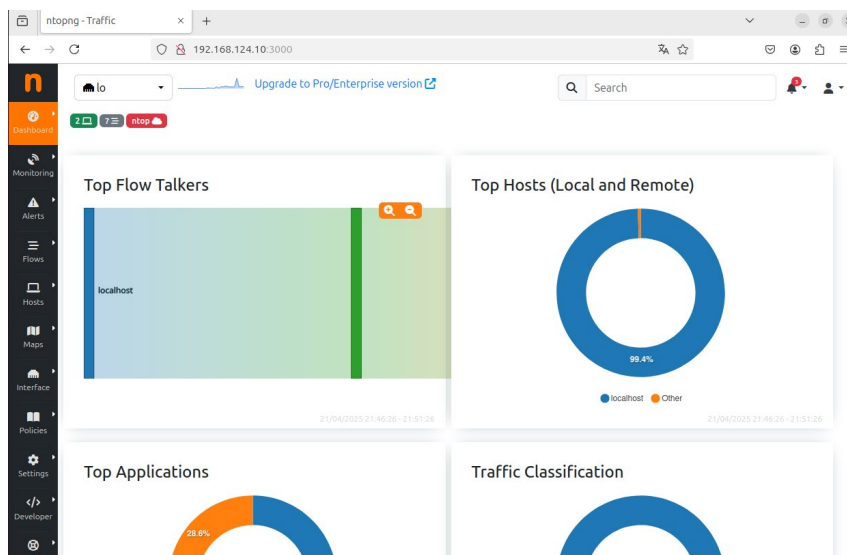


B. Análisis histórico y en tiempo real

Cacti es una herramienta de código libre tradicionalmente utilizada para el análisis histórico y en tiempo real. Aunque sigue siendo funcional y está mantenida, su uso ha disminuido frente a alternativas más actuales como Grafana con Prometheus, Zabbix o Netdata, que ofrecen una visualización avanzada, integración más sencilla y mayor flexibilidad.

C. Estado instantáneo de la red

ntopng es una herramienta moderna y libre que permite analizar el tráfico en tiempo real de forma visual y organizada. Para diagnosticar problemas en tiempo real es necesario visualizar qué sucede en la red (tipos de datos, origen y destino).

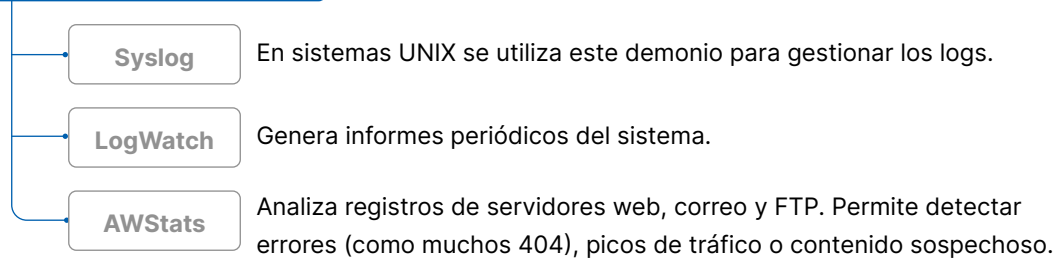


D. Gestión y análisis de registros (logs)

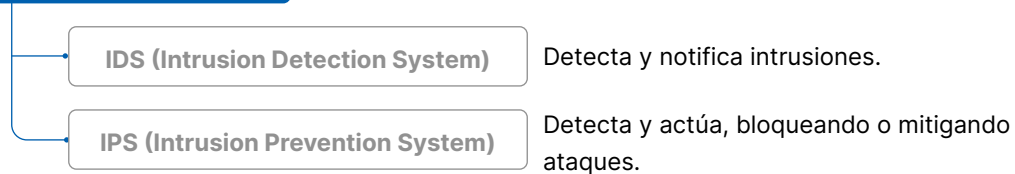
Los registros del sistema son muy necesarios para detectar ataques e irregularidades. Para asegurar su integridad:

1. El sistema local recoge los registros.
2. Se reenvían a un servidor remoto centralizado.
3. Se firman electrónicamente para prevenir manipulaciones.

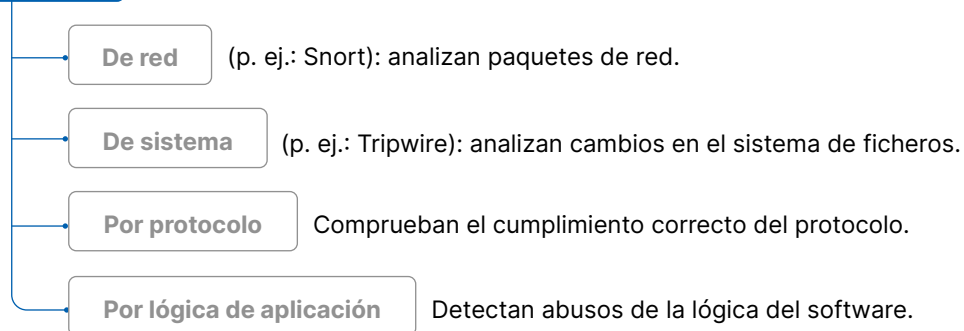
Análisis de registros



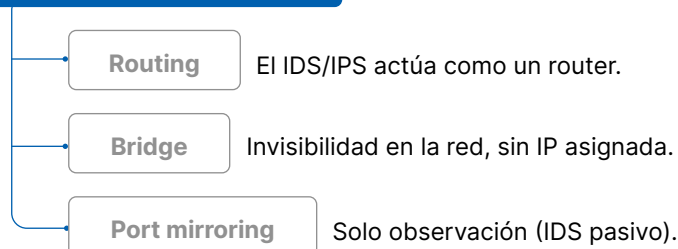
Sistemas IDS/IPS



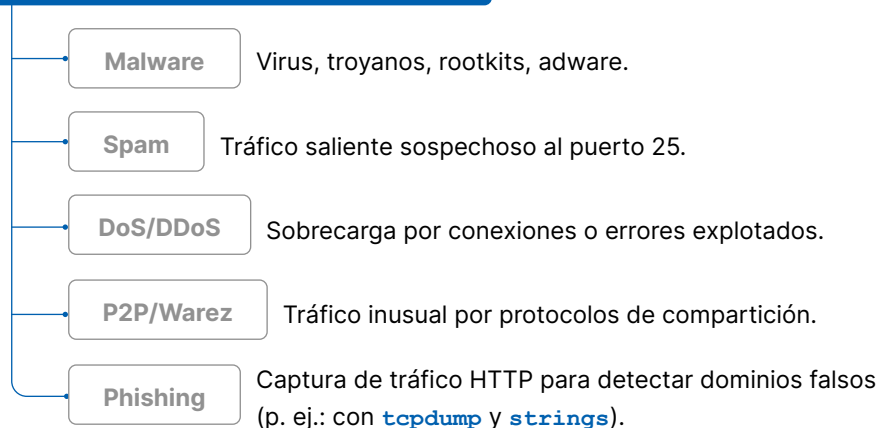
Tipos



Modos de despliegue



Análisis de amenazas comunes



Prevención y antivirus

Un sistema comprometido puede convertirse en punto de propagación. Es necesario escanear periódicamente con antivirus.

ClamAV

Es una solución antivirus libre para sistemas Linux que permite detectar malware mediante escaneos programados o bajo demanda.



VIDEOLAB

Para consultar el siguiente vídeo sobre la **Instalación de Nagios**, escanea el código QR o [pulsa aquí](#).

Aprenderemos a instalar Nagios desde cero en un entorno Ubuntu 24. Se trata de uno de los software más utilizados para vigilar el estado de los servidores. Veremos todos los pasos que hay que dar y los comandos que debemos introducir para configurarlo, compilarlo e instalarlo.

2.2. Cortafuegos en equipos y servidores: instalación, configuración y buenas prácticas

DEFINICIÓN

Un **cortafuegos (firewall)** es un sistema diseñado para controlar el acceso entre redes y sistemas. Este dispositivo puede funcionar como un elemento de red que gestiona los permisos de acceso entre diferentes redes y niveles de confianza, o como una aplicación instalada en los equipos (hosts) para proteger las conexiones tanto entrantes como salientes del sistema, en relación con el resto de la red.

A. Ámbito de protección del cortafuegos

Podemos clasificar los cortafuegos en función del objetivo que protegen:

- » **Cortafuegos de red:** se sitúan como un elemento en la infraestructura de red, regulando las conexiones entre distintos segmentos. Su función principal es filtrar el tráfico que atraviesa la red, más allá de las conexiones dirigidas al propio firewall. Los principales fabricantes son Juniper, Cisco, Check Point, Fortinet y Stonesoft.
- » **Cortafuegos personales o de sistema:** se instalan como una aplicación más en el sistema operativo. Su función es filtrar tanto el tráfico entrante (proveniente de otros sistemas) como el saliente (generado por aplicaciones locales).

A ser posible, se recomienda usar un cortafuegos de red en lugar de instalar uno personal en cada equipo. Las ventajas son:

- » **Centralización de las políticas de seguridad:** los cambios de direccionamiento afectan a una sola configuración, no a cada equipo individualmente.
- » **Control de accesos:** si se desactiva el firewall en un equipo, este sigue estando protegido por el cortafuegos de red.

B. Base del filtrado

Podemos clasificar los cortafuegos según el nivel de inspección del tráfico:

- » **Filtrado de paquetes sin estado (stateless):** deciden en base a la información del paquete individual: IP de origen y destino, protocolo y puertos.
- » **Filtrado con estado (stateful):** mantienen una tabla de estado de conexiones activas. Pueden identificar si un paquete es parte de una conexión válida, nueva o sospechosa.
- » **Filtrado a nivel de aplicación (proxy):** comprenden el protocolo de aplicación (HTTP, SMTP, etc.). Permiten un análisis profundo del contenido, a costa de un mayor uso de recursos.

C. Política por defecto

Cualquier cortafuegos puede configurarse con dos enfoques:

- » **Política restrictiva (lista blanca):** todo el tráfico es denegado salvo el explícitamente permitido.
- » **Política permisiva (lista negra):** todo el tráfico es permitido salvo el explícitamente denegado.

La política **restrictiva** es más segura, ya que minimiza el riesgo de tráfico malicioso inadvertido.

D. Filtrado por rango o por dirección IP

El filtrado puede aplicarse a direcciones individuales o rangos de red (segmentos). En general, conviene:

- » Separar los sistemas por función en distintos segmentos.
- » Establecer reglas por segmento, no por equipo individual (salvo excepciones justificadas).

E. Tipos de bloqueo

- » **DROP:** descarta el paquete sin notificar al emisor.
- » **REJECT:** descarta el paquete, pero informa al emisor mediante un mensaje ICMP.

Se recomienda **DROP por defecto** (más seguro ante ataques) y **REJECT en redes internas** (facilita el diagnóstico).

El **protocolo UDP no establece conexión**, por lo que la forma de detectar puertos abiertos o filtrados se basa en las respuestas ICMP. Se puede utilizar **tcpdump** y **nc(netcat)** para observar el comportamiento.

F. Modos de configuración del cortafuegos

- » **Modo bridge (transparente):** sin dirección IP propia, actúa como puente entre interfaces. Ideal para pruebas o para filtrado sin modificar el encaminamiento.
- » **Modo router (encaminamiento):** el cortafuegos actúa como gateway entre redes. Es el modo más común.

G. Funciones adicionales

- » **NAT/PAT:** traduce direcciones IP (SNAT, DNAT) y puertos (PAT) para permitir acceso a redes privadas mediante una IP pública.
- » **VPN:** redes virtuales privadas cifradas sobre Internet.
- » **IDS/IPS:** algunos cortafuegos integran la detección y la prevención de intrusiones (puede requerir hardware adicional).

H. Limitaciones de los cortafuegos

- » No protegen contra vulnerabilidades de servicios permitidos.
- » No controlan ataques entre equipos del mismo segmento.
- » El tráfico puede encapsularse en protocolos como ICMP o DNS (túneles).
- » No garantizan que el protocolo que usa un puerto sea el esperado (requiere inspección profunda).

I. Cortafuegos en Linux

iptables

Es la herramienta que permite definir reglas de filtrado en sistemas Linux. Internamente, se basa en el framework del kernel llamado **netfilter**.

Tablas de iptables

filter

Filtrado de paquetes estándar (**INPUT**, **OUTPUT**, **FORWARD**).

nat

Traducción de direcciones y puertos (**PREROUTING**, **POSTROUTING**, **OUTPUT**).

mangle

Modificación avanzada de paquetes.

raw

Filtrado previo al seguimiento de conexiones (**conntrack**).

Cadenas (chains)

Predefinidas

INPUT, **OUTPUT**, **FORWARD** (según tabla).

Personalizadas

Se pueden crear y enlazar a otras cadenas (**iptables -N nombre**).

Acciones comunes

ACCEPT

Permite el paquete.

DROP

Descarta el paquete.

REJECT

Descarta el paquete e informa al emisor.

QUEUE

Pasa el paquete a espacio de usuario.

RETURN

Vuelve a la cadena anterior.

Opciones comunes para reglas

-s/-d

IP origen/destino.

-i/-o

Interfaz de entrada/salida.

-p

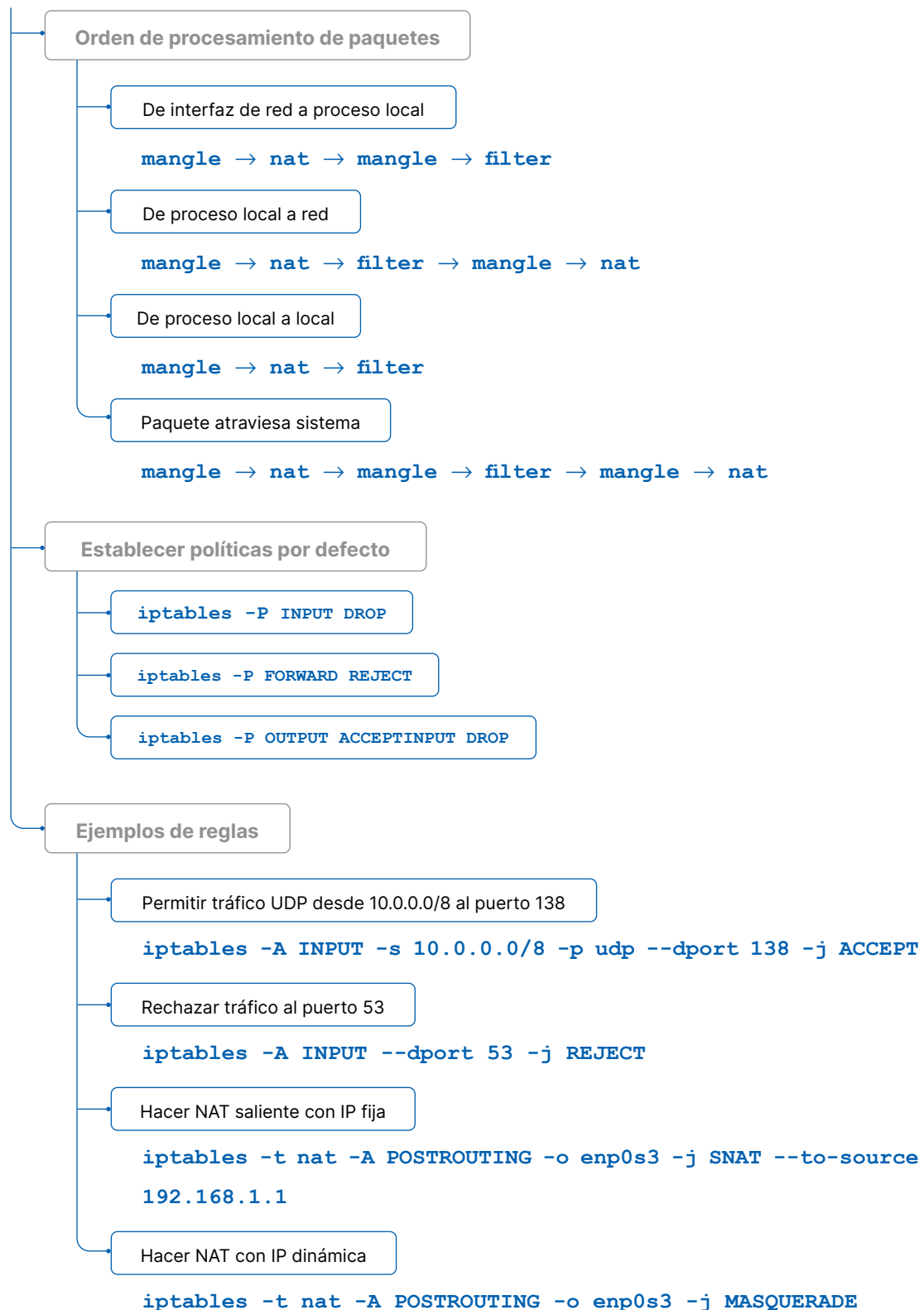
protocolo (**tcp**, **udp**, **icmp**).

--sport/--dport

Puerto origen/destino.

--state

Estado de la conexión (**NEW**, **ESTABLISHED**, **RELATED**, **INVALID**).



La mayoría de las distribuciones Linux incluyen **herramientas gráficas** para la gestión básica de reglas de firewall. Sin embargo, para configuraciones avanzadas, se recomienda utilizar la línea de comandos o herramientas más especializadas. Hoy en día, **nftables** ha reemplazado a **iptables** como la solución estándar en sistemas Linux modernos, ofreciendo una sintaxis más unificada, lo que proporciona mayor eficiencia.

Herramientas como **FWBuilder** fueron populares en el pasado, pero su desarrollo está detenido y no se recomienda su uso en entornos actuales. Para la gestión de firewalls en otras plataformas, como routers Cisco (mediante CLI o ASDM) o cortafuegos BSD como **pf**, **ipfilter** o **ipfw**, existen utilidades específicas y mantenidas activamente, como **pfSense** en el caso de **pf**.

nftables

Es la herramienta actual y recomendada para gestionar cortafuegos en Linux. Sustituye a **iptables**, **ip6tables**, **arptables** y **ebtables** bajo una sola interfaz unificada y más eficiente.

Ventajas principales

- Sintaxis más clara y flexible.
- Un único framework para IPv4, IPv6, ARP y bridges.
- Mejor rendimiento y menor consumo de memoria.
- Mayor facilidad para mantener reglas complejas.

Acciones comunes

```
nft add table inet filtro  
  
nft add chain inet filtro entrada { type  
  filter hook input priority 0 \; }  
  
nft add rule inet filtro entrada ip saddr  
  10.0.0.0/8 udp dport 138 accept
```

Comando equivalente al ejemplo anterior en iptables

```
iptables -A INPUT -s 10.0.0.0/8 -p udp --dport 138 -j ACCEPT
```

Migración

Para facilitar la transición, se puede usar la herramienta **iptables-translate** para convertir reglas existentes a sintaxis nftables:

```
iptables-translate -A INPUT -s 10.0.0.0/8 -p udp  
--dport 138 -j ACCEPT
```

2.3. Interpretación y uso como soporte de documentación técnica

A. Fases de implementación segura de un sistema

Desde el punto de vista de la seguridad, un sistema debe pasar por tres fases antes de entrar en funcionamiento. Estas fases aseguran que la configuración de un sistema de pruebas no se convierta en una puerta de entrada para posibles intrusos. Las fases para una instalación segura del sistema son:

1 Entorno de pruebas

- Debe estar **aislado del exterior** para evitar la exposición a ataques.
- Ideal para realizar las primeras pruebas de funcionamiento.
- No se espera una configuración de seguridad estricta al inicio, pero sí se deben minimizar los riesgos.

2 Entorno de preproducción

- El sistema ya debe estar configurado como si estuviera en producción.
- Puede permitir el acceso a personal externo para validaciones previas.
- Servicios correctamente configurados y publicados, pero con **acceso limitado**.

3 Entorno de producción

- El sistema está listo para funcionar de forma pública y estable.
- Una mayor exposición implica **mayores controles de seguridad y vigilancia**.
- Es fundamental tener el sistema **documentado, monitorizado** y con políticas de seguridad activas.

4 Documentación del sistema

- Es imprescindible consultar la documentación oficial del producto, usualmente en inglés.
- Realizar búsquedas en Internet puede ayudar con configuraciones predefinidas, pero siempre se debe verificar la fiabilidad de las fuentes, ya que podrían contener errores de seguridad, incluso intencionados.
- Documentar todas las fuentes y procedimientos es esencial. Almacenar esta información en un sistema de gestión del conocimiento (como MediaWiki) permite reutilizar el conocimiento en futuras instalaciones o mantenimientos.

B. Procedimientos operativos

Una vez instalado el sistema, es necesario documentar cómo mantenerlo operativo. A continuación, podemos ver los procedimientos fundamentales:

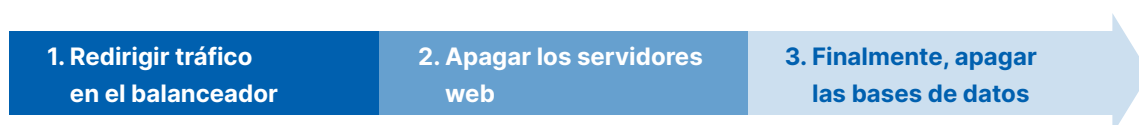
- » **Arranque del sistema:** dependiendo de la complejidad del sistema, el arranque puede ser sencillo o complejo (con dependencias entre servicios). Por ejemplo, en un clúster con bases de datos, servidores web y balanceadores de carga, el orden debe ser:



Un orden incorrecto puede provocar **sobrecargas o fallos** en el arranque.

IMPORTANTE

- » **Verificación de funcionamiento:** una vez iniciado, hay que validar que el sistema y sus servicios funcionan correctamente, tanto de forma individual como integrada. Por ejemplo, comprobar por separado el servidor web y la base de datos, y luego probar una consulta real desde el servidor web a la base de datos.
- » **Verificación de configuración:** antes de aplicar cualquier cambio, la configuración debe **validarse**. Aplicar cambios sin verificación puede causar caídas de servicio. Es fundamental documentar los pasos exactos para modificar y comprobar las configuraciones.
- » **Apagado controlado:** en sistemas más complejos, el apagado también debe seguir un orden. Continuando con el ejemplo anterior:



Así se evitan peticiones pendientes que no puedan resolverse y provoquen saturación.

C. Monitorización del sistema

Todo sistema debe estar monitorizado desde antes de su puesta en producción. Esto permite detectar errores de forma temprana y tomar decisiones correctivas de manera proactiva.

La monitorización ayuda a asegurar que los servicios se mantengan operativos dentro de los niveles de disponibilidad establecidos por el SLA (Service Level Agreement).

La **disponibilidad** se mide como el porcentaje de tiempo que el sistema permanece en funcionamiento. Es la conocida regla de los nueves:

DISPONIBILIDAD	TIEMPO DE CAÍDA ANUAL APROX.	TIEMPO DE CAÍDA MENSUAL APROX.
99 %	87 horas	7 horas
99,9 %	8 horas	43 minutos
99,99 %	52 minutos	4 minutos
99,999 %	5 minutos	26 segundos
99,9999 %	30 segundos	2,5 segundos

Tabla 1. Regla de los nueves.

D. Supervisión y monitores reactivos

Una práctica clave para mejorar la disponibilidad del sistema es usar herramientas que supervisen de manera automática los servicios y tomen acciones correctivas ante errores. Se recomienda **Monit**, una herramienta de código libre que permite:

- » Supervisar servicios del sistema, archivos y recursos (CPU, disco, RAM).
- » Definir acciones automáticas, como reiniciar un servicio, enviar alertas o ejecutar scripts.
- » Acceso mediante una interfaz web para gestión y visualización.
- » Integración con sistemas modernos (`systemd`, `cron`, etc.).

Este es un ejemplo básico de configuración (`/etc/monitrc`):

```
check process nginx with pidfile /run/nginx.pid
  start program = "/etc/init.d/nginx start"
  stop program = "/etc/init.d/nginx stop"
  if failed port 80 protocol http then restart
```

Existen otras alternativas:

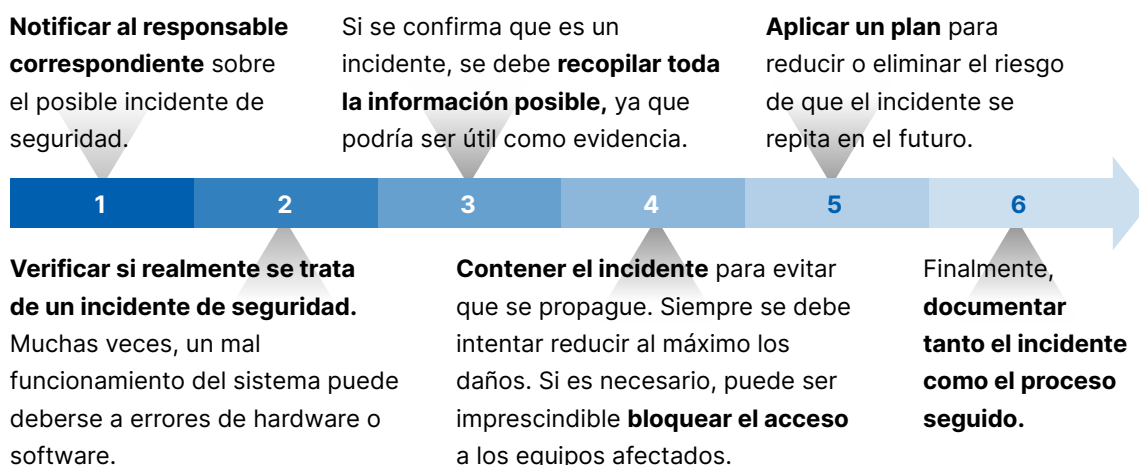
- » **systemd**: en la mayoría de las distribuciones Linux actuales, **systemd** permite configurar servicios con reinicio automático (**Restart=always**) y temporizadores (**.timer**) para tareas programadas.
- » **supervisord**: ideal para entornos de desarrollo o contenedores, permite gestionar múltiples procesos con reinicio automático y salida controlada de logs.
- » **runit** o **s6**: sistemas de inicialización alternativos a **systemd**, ligeros y adecuados para sistemas embebidos o con filosofía Unix clásica.

Por su parte, **DAEMON tools**, aunque fue útil en su época, **ya no se mantiene** y no incluye funcionalidades actuales ni soporte activo. No se recomienda su uso en nuevos sistemas.

2.4. Documentación de incidentes de seguridad

Cuando ocurre un incidente de seguridad, lo primero es **notificarlo** a los responsables de los sistemas afectados y actuar con mucha precaución.

Una de las prácticas más comunes y que **nunca se tendría que hacer** es acceder a los equipos involucrados y comenzar a investigar sin tener claro qué está sucediendo. De esta forma, es fácil destruir pistas cruciales que podrían ayudar a descubrir el origen del problema. Por lo tanto, lo primero que se debe hacer es mantener la calma y seguir estos pasos:



Para elaborar un informe completo sobre el incidente, este debe incluir los siguientes apartados:

A. Descripción

El documento debe comenzar con una introducción sobre el incidente y un conjunto de datos básicos, como:

- » Breve descripción del incidente (título).
- » Personal implicado.
- » Fecha y hora de inicio del incidente.
- » Fecha y hora en que se considera finalizado.
- » Nivel de afectación: se pueden establecer diferentes niveles con criterios específicos según la organización. Generalmente, los niveles son:
 - **Grave:** implica un problema de seguridad que ha causado daños en los sistemas afectados. Requiere resolución inmediata y continua. Por ejemplo: si la base de datos principal de la organización se cae, es necesaria una respuesta inmediata para restaurarla.
 - **Moderada:** afecta parcialmente al servicio o a componentes no críticos, y se puede resolver durante la jornada laboral siguiente. Por ejemplo: un sistema interno se ve interrumpido por un ataque de denegación de servicio, pero puede ser restaurado una vez que se reanude el trabajo.
 - **Leve:** es un problema detectado que no afecta al funcionamiento del sistema, pero que se debe resolver en el largo plazo, como durante la siguiente semana. Por ejemplo: un error de programación en algún software que requiere una actualización.

B. Resumen

Tras la descripción, se debe proporcionar un resumen breve del problema, los efectos, las causas y las medidas tomadas para evitar que el incidente se repita. Este resumen debe ser comprensible incluso para una persona no técnica.

C. Análisis

El análisis del incidente es el cuerpo principal del informe. Debe permitir seguir paso a paso qué ocurrió y cómo se resolvió. Esta parte se divide en tres secciones:

1. Procedimiento y metodología:

Es crucial detallar cómo se actuó frente al incidente para entender posteriormente las decisiones tomadas durante la resolución. Aunque el resultado final sea el mismo, el método utilizado puede afectar a las conclusiones. Por ejemplo, si no se verificó la integridad de un archivo de registro, es posible que ese archivo haya sido alterado.

Una vez recogidos los datos, es importante **verificar la validez de la información obtenida**. Para garantizar que los datos del sistema son reales, se recomienda utilizar herramientas que estén compiladas de manera estática (sin bibliotecas del sistema que puedan haber sido manipuladas). Los archivos deben transmitirse de manera que no puedan ser modificados, utilizando métodos modernos y seguros.

Sería recomendable el uso de **dispositivos USB cifrados** con herramientas como **BitLocker** (Windows) o **LUKS** (Linux), que aseguran que los datos no sean alterados durante su transferencia. Estos dispositivos requieren una contraseña o clave para acceder a los datos, lo que agrega una capa extra de seguridad.

Es necesario que los resultados se registren en un sistema remoto que permita la verificación de los archivos mediante algoritmos de **hashing** modernos, como **SHA-256** o **SHA-3**. Estos algoritmos generan un valor único de longitud fija para cada archivo, lo que permite verificar su integridad y detectar cualquier alteración. Comparado con SHA-1, **SHA-256** ofrece una mayor resistencia a los ataques de colisión y es la opción recomendada en la actualidad.

Por ejemplo, **SHA-256** genera un valor de 256 bits, mucho más robusto frente a intentos de modificación de los datos, lo que garantiza la autenticidad de la información durante el análisis de incidentes de seguridad.

2. Documentación:

Durante la resolución de un incidente, es probable que se consulte documentación sobre el tema, ya que es imposible tener todos los detalles memorizados para actuar de manera óptima. Es recomendable **anotar toda la documentación** utilizada, tanto interna como externa.

Si se consultó documentación interna, es importante identificarla para poder corregirla o actualizarla si es necesario. En cambio, si se utilizó documentación externa, se podrá contrastar la información para verificar que se actuó de acuerdo con los procedimientos adecuados y, posteriormente, generar documentación interna para mejorar la respuesta ante futuros incidentes.

3. Incidencias detectadas:

Al investigar un incidente, a menudo se detectan otros posibles puntos de acceso al sistema. Es fundamental **destacar estas incidencias** adicionales, ya que pueden revelar vulnerabilidades que deben ser corregidas.

4. Plan de acción:

Una vez comprendido el problema, es necesario tomar medidas para evitar que se repita. Existen varias situaciones comunes que deben ser consideradas:

- » **Mala configuración:** si el problema fue causado por una configuración incorrecta, se debe revisar toda la configuración del servicio afectado, ya que podrían encontrarse otros problemas similares.
- » **Errores sin actualización disponible:** si se detecta un error en el servicio que no tiene un parche disponible, es importante considerar la desactivación del servicio hasta que se resuelva el problema para evitar futuras intrusiones. Si no es posible desactivar el servicio, se deben buscar técnicas para mitigar el riesgo. El uso de técnicas como el **chroot** (que aísla un servicio de otros procesos del sistema) puede ser útil en estos casos.
- » **Errores con actualización disponible:** si el incidente revela la necesidad de un parche, debe especificarse el parche que se debe aplicar y probarlo en un entorno de pruebas antes de implementarlo en el sistema en producción.
- » **Mal uso de servicios de red:** si el problema es causado por un uso indebido de los recursos de la red, se debe establecer una política de uso adecuado para evitar que un usuario malintencionado afecte al sistema de forma masiva.

En algunos casos, el problema puede no ser el mal uso de la red, sino una limitación del propio protocolo utilizado. Un claro ejemplo es el protocolo **SMTP** y su relación con el correo no deseado. Debido a la estructura del correo electrónico, no se puede verificar a priori si un servidor está enviando correo legítimo o no deseado.

D. Anexos

Para terminar, se debe incluir toda la **información adicional relevante** que pueda ayudar a comprender el incidente y las acciones tomadas, como fragmentos de registros o comandos ejecutados que sean útiles para un análisis posterior.

2 CASO PRÁCTICO



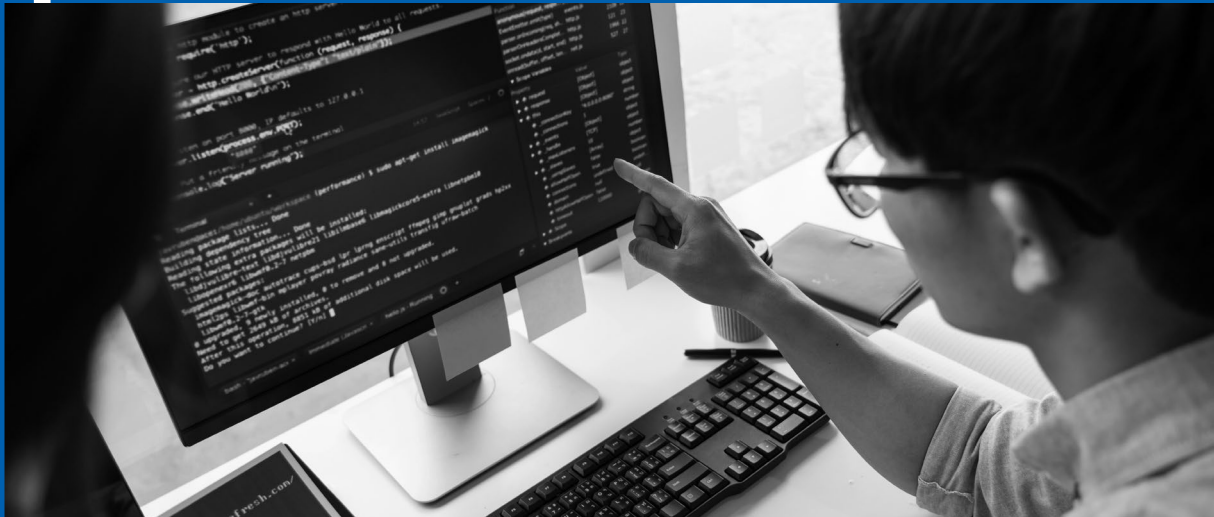
INSTALACIÓN Y CONFIGURACIÓN DE NTOPNG EN UBUNTU

Debes configurar un sistema de monitoreo de tráfico de red utilizando **ntopng** en un sistema Ubuntu, permitiendo la visualización en tiempo real de estadísticas de red a través de una interfaz web.

Solucionario casos prácticos

1

SOLUCIÓN CASO PRÁCTICO



AUDITORÍA BÁSICA DE SEGURIDAD INTERNA

Antes de iniciar los escaneos, configura manualmente la interfaz de red con los siguientes comandos:

1. Crear archivo **/etc/netplan/01-static-ip.yaml** con este contenido:

```
network:
  version: 2
  renderer: networkd
  ethernets:
    enp0s3:
      addresses: [192.168.10.13/24]
      dhcp4: no
```

2. Aplicar configuración:

```
sudo netplan apply
```

3. Verificar IP:

```
ip address show enp0s3
```

4. Haz lo mismo con el servidor. Si tienes problemas para hacerlo, puedes seguir este tutorial: <https://www.youtube.com/watch?v=Vwm9cAL3b5w>.

5. Realiza un escaneo de toda la subred para identificar los hosts activos:

```
nmap -sn 192.168.10.0/24
```

6. Escanea los 100 puertos más comunes en un host específico:

```
nmap --top-ports 100 192.168.10.201
```

7. Escanea un rango específico de puertos (del 1700 al 1800):

```
nmap -p 1700-1800 192.168.10.201
```

8. Identificación del software de los servicios encontrados en el escaneo anterior:

```
nmap -sV 192.168.10.201
```

9. Repite el análisis para el rango 1700-1800 (puedes centrarte en los puertos que estén abiertos). Algunos protocolos como L2TP (puerto 1701) no exponen versiones del software, pero deberías indicar a qué servicio pertenece y su función.

10. Intenta detectar el sistema operativo del servidor destino:

```
nmap -O 192.168.10.201
```

Aquí tienes una ayuda extra: <https://www.youtube.com/watch?v=U5A3szBzne0&t=920s>.

2 SOLUCIÓN CASO PRÁCTICO



INSTALACIÓN Y CONFIGURACIÓN DE NTOPNG EN UBUNTU

A. Requisitos previos

- » **Sistema operativo:** Ubuntu 20.04 LTS como mínimo.
- » **Acceso:** privilegios de superusuario (**sudo**).
- » **Conexión a Internet:** para descargar paquetes y actualizaciones.

B. Instalación

1. Actualizar el sistema:

```
sudo apt update && sudo apt upgrade -y
```

2. Instalar dependencias necesarias:

```
sudo apt install wget gnupg software-properties-common -y
```

3. Agregar el repositorio oficial de ntopng:

```
wget https://packages.ntop.org/apt/20.04/all/apt-ntop.deb  
sudo dpkg -i apt-ntop.deb
```

4. Actualizar los repositorios:

```
sudo apt update
```

5. Instalar ntopng y componentes relacionados:

```
sudo apt install pfring-dkms nprobe ntopng n2disk cento -y
```

C. Configuración

1. Identificar las interfaces de red disponibles:

```
ntopng -h
```

2. Al final del comando, se listarán las interfaces disponibles, por ejemplo:

```
Available interfaces (-i <interface index>) :  
1. lo  
2. enp1s0
```

3. Editar el archivo de configuración de **ntopng**:

```
sudo nano /etc/ntopng/ntopng.conf
```

4. Añadir o modificar las siguientes líneas:

```
# Nombre de la interfaz de red a monitorear  
-i=2  
  
# Puerto HTTP del servidor web embebido  
-w=3000
```

Reemplaza 2 con el índice correspondiente a la interfaz que desees monitorear.

5. Iniciar y habilitar el servicio ntopng:

```
sudo systemctl start ntopng  
sudo systemctl enable ntopng
```

6. Verificar el estado del servicio:

```
sudo systemctl status ntopng
```

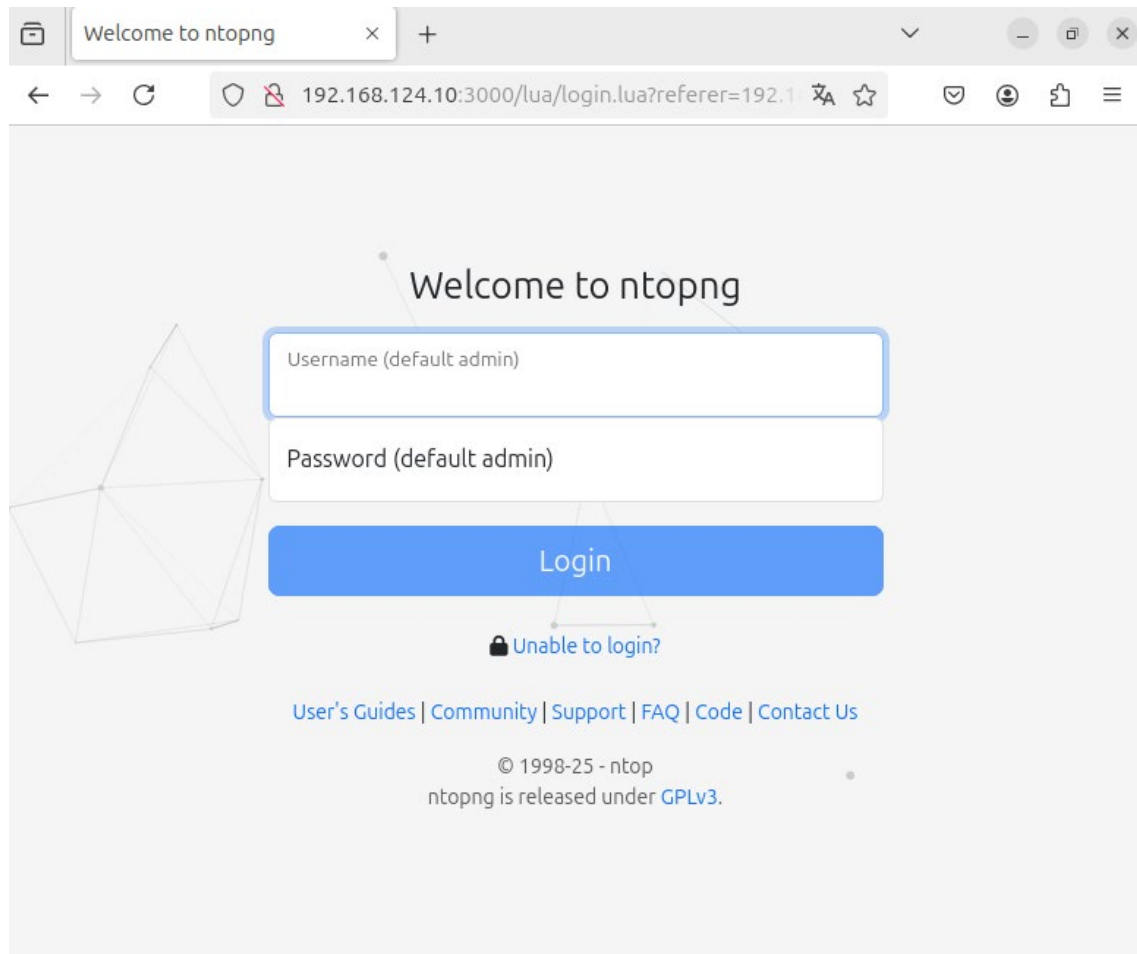
D. Acceso a la interfaz web

Una vez iniciado el servicio, puedes acceder a la interfaz web de **ntopng** desde un navegador web ingresando la dirección IP del servidor seguida del puerto configurado:

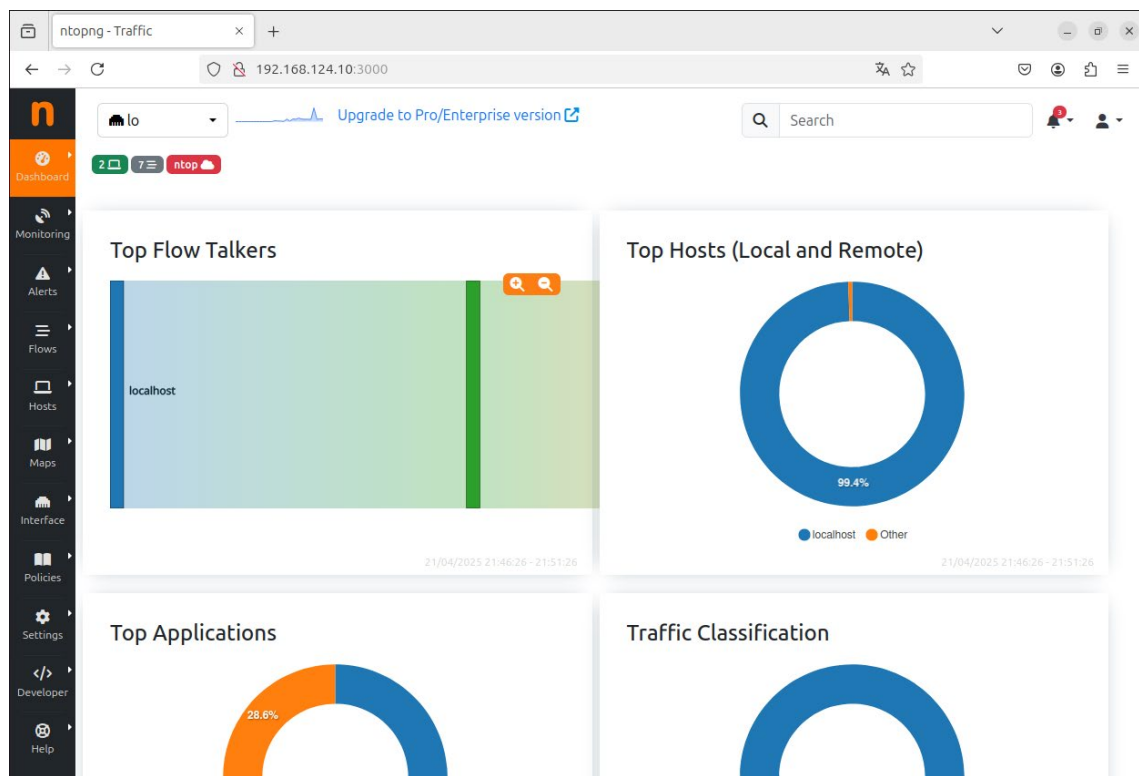
```
http://<IP_DEL_SERVIDOR>:3000
```

» **Usuario:** admin

» **Contraseña:** admin



Cambia la contraseña predeterminada después del primer inicio de sesión por razones de seguridad. Una vez dentro de la interfaz web, puedes explorar diversas funcionalidades:



- » **Dashboard:** vista general del tráfico de red.
- » **Hosts:** información detallada sobre los hosts conectados.
- » **Flujos:** análisis de flujos de datos entre hosts.
- » **Protocolos:** estadísticas por tipo de protocolo.
- » **Geolocalización:** ubicación geográfica de las IP conectadas.
- » **Alertas:** configuración y visualización de alertas de tráfico inusual.

E. Actividades para ver su uso

Para profundizar en el uso de **ntopng**, se proponen las siguientes actividades:

- » **Monitoreo de tráfico en tiempo real:** generar tráfico desde diferentes dispositivos y observar cómo se refleja en la interfaz de ntopng.
- » **Análisis de protocolos:** identificar los protocolos más utilizados en la red y su proporción de uso.
- » **Detección de anomalías:** configurar alertas para detectar picos inusuales de tráfico o conexiones sospechosas.
- » **Geolocalización de IP:** analizar la distribución geográfica de las conexiones entrantes y salientes.

F. Recursos adicionales

- » **Documentación oficial de ntopng:** <https://www.ntop.org/guides/ntopng/>.
- » **Repositorio de paquetes de ntopng:** <https://packages.ntop.org/apt-stable/>.

Enlaces de interés

Antivirus: <https://www.ocu.org/tecnologia/antivirus/consejos/antivirus-gratuitos>

Ocultar el SSID y evitar conexiones no deseadas:

<https://www.youtube.com/watch?v=WIVkEHPqQIU>

Dirección MAC en redes wifi:

<https://www.redeszone.net/tutoriales/redes-wifi/saber-direccion-mac-dispositivos-wifi/>

MAC spoofing:

<https://www.dongee.com/tutoriales/que-es-para-que-sirve-como-funciona-mac-spoofing/>

WPA2 (Wi-Fi Protected Access 2): <https://www.avg.com/es/signal/what-is-wpa2>

WPA3 (Wi-Fi Protected Access 3):

<https://www.incibe.es/ciudadania/blog/wpa3-el-protocolo-de-seguridad-configurar-en-tu-router>

Criptografía simétrica y asimétrica:

<https://www.redeszone.net/tutoriales/seguridad/criptografia-algoritmos-clave-simetrica-asimetrica/>

Encriptación simétrica y asimétrica: <https://www.youtube.com/watch?v=wDpqrasDmxM>

Firma digital: <https://www.proofpoint.com/es/threat-reference/digital-signature>

NMAP para escaneo de vulnerabilidades:

<https://www.youtube.com/watch?v=U5A3szBzne0&t=920s>

NAGIOS XI: <https://www.youtube.com/watch?v=HmurbyEOGGI>

Instalación de Zabbix en Ubuntu: <https://www.youtube.com/watch?v=oKLIm4kxISQ>

Monitorización con Grafana y Prometheus:

<https://www.youtube.com/watch?v=pGSkPutCKtQ>

Instalación Checkmk en Ubuntu 24.04: <https://www.youtube.com/watch?v=duK-ePZZ6r4>

Soluciones de monitorización gratuitas para servidores Linux:

<https://www.youtube.com/watch?v=Nr92b1eFRE0&t=104s>

Instalación de Cacti en Ubuntu:

<https://shape.host/resources/como-instalar-la-herramienta-de-monitoreo-cacti-en-ubuntu-22-04>

Instalación de Logwatch en Ubuntu: <https://www.youtube.com/watch?v=zNviSDBXP4>

Logwatch en servidores Ubuntu:

<https://documentation.ubuntu.com/server/how-to/observability/install-logwatch/index.html>

Zabbix para monitoreo: <https://www.youtube.com/watch?v=TxL6olgrwaY>

AWStats para análisis de logs:

<https://tecadmin.net/install-awstats-apache-log-analyzer-on-ubuntu/>

Instalación y configuración de Snort 3.0 en Ubuntu:

<https://www.youtube.com/watch?v=cD-DoKLzq2s>

CLAM AV Antivirus:: https://www.youtube.com/watch?v=_e5c-qW4V4k&t=176s

Modo bridge en routers:

<https://www.xataka.com/basics/modo-bridge-que-sirve-como-configurarlo-tu-router>

Tabla de enrutamiento en routers:

<https://www.redeszone.net/tutoriales/redes-cable/tabla-enrutamiento-router-que-es/>

VPN en ciberseguridad: <https://www.youtube.com/watch?v=giw7jODRI7M>

IDS e IPS: <https://www.youtube.com/watch?v=6-asM2Bh2yE>

Reglas de Iptables: <https://fp.josedomingo.org/seguridadgs/u03/iptables.html>

Nftables en Linux: <https://www.youtube.com/watch?v=PeMBfZ7ummg>

Configuración de Nftables:

<https://www.redeszone.net/tutoriales/seguridad/nftables-firewall-linux-configuracion/>

Nftables Sets: <https://www.youtube.com/watch?v=YLVKuA4kiMA>

Entornos de pruebas (testing environments):

<https://www.imagar.com/blog-desarrollo-web/que-es-un-entorno-de-pruebas/>

Entorno de producción:

<https://lenguajejs.com/nodejs/despliegue-produccion/que-es/>

Monitoreo con Monit:

<https://help.clouding.io/hc/es/articles/360010124680-Monitorizar-mi-servidor-Ubuntu-con-Monit>

Instalación Monit en Ubuntu:

<https://www.youtube.com/watch?v=JntzOwe1K9Q>

Systemd y gestión de servicios:

<https://somebooks.es/administrar-servicios-systemd-systemctl-ubuntu-parte-1/>

Funciones hash: https://www.nervos.org/es/knowledge-base/what_is_a_hash_function

Aislamiento de procesos con chroot:

https://www.youtube.com/watch?v=edtnPMVp_vU

Gestión de ciberincidentes (Guía Nacional INCIBE):

https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_nacional_notificacion_gestion_ciberincidentes.pdf

Autenticación de dos factores:

<https://www.incibe.es/ciudadania/tematicas/contrasenas-seguras/autenticacion-de-dos-factores>

Botnets: <https://www.incibe.es/aprendeciberseguridad/botnet>

Configuración de puertos:

<https://www.redeszone.net/tutoriales/configuracion-puertos/puertos-tcp-udp/>

Cortafuegos: <https://www.youtube.com/watch?v=kH6oP6JUnHI>

Enrutadores: <https://www.youtube.com/watch?v=8Py5-otzhD4>

Envío masivo de mails: <https://www.youtube.com/watch?v=ln5qhNpOKg0>

Historia de Internet: <https://www.fib.upc.edu/retro-informatica/historia/internet.html>

Hoax: <https://www.incibe.es/aprendeciberseguridad/hoax-bulo>

Ingeniería social: <https://www.youtube.com/watch?v=TentnM1-lg0&t=3s>

Microsoft vs. Google:

<https://www.nasdaq.com/articles/better-artificial-intelligence-stock-microsoft-vs-alphabet>

Pharming:

https://www.kaspersky.es/resource-center/definitions/pharming?srsId=AfmBOowdR7DfDecxN6ZpixWKJ9wokoO4kkPW7KFAHIMZvE7YKUp_jV3

Phishing: <https://www.youtube.com/watch?v=vl0IRAIDMIU>

Red ad hoc: <https://ccnadesdecero.es/red-ad-hoc-inalambrica-wanet/>

Redes cableadas: <https://www.nvtecnologias.com/blog/blog-1/redes-cableadas-41>

Reservar una dirección IP por MAC en un router TP-Link:

<https://www.youtube.com/watch?v=Xy0AuHbEVO4>

Saber más sobre FTP: <https://www.xataka.com/basics/ftp-que-como-funciona>

Saber más sobre ingeniería social:

https://latam.kaspersky.com/resource-center/definitions/what-is-social-engineering?srsId=AfmBOore_FZ0MBjsY3FOF4hK07uHqsKmrKPJXKfGWPz06IXd8xZtNpx3

Saber más sobre SNMP:

<https://www.fortinet.com/lat/resources/cyberglossary/simple-network-management-protocol>

Sistemas de detección de intrusos (IDS):

<https://www.youtube.com/watch?v=vQNB7nenT2E>

Sniffers:

<https://www.cdmon.com/es/blog/sniffers-del-uso-legitimo-a-las-amenazas-ocultas>

SSH: <https://www.youtube.com/watch?v=fvq8HdaIAZM>

SSL, TLS y HTTPS: <https://www.digicert.com/es/what-is-ssl-tls-and-https>

Tipos de redes más importantes:

<https://www.ionos.es/digitalguide/servidores/know-how/los-tipos-de-redes-mas-conocidos/>

Tutorial de Wireshark: https://www.youtube.com/watch?v=a_4MjV_-7Sw

VPN (Virtual Private Network):

<https://www.xataka.com/basics/que-es-una-conexion-vpn-para-que-sirve-y-que-ventajas-tiene>

Glosario

- » **802.1X:** Estándar de autenticación en redes, usado en WPA/WPA2.
- » **Baiting:** Engaños que usan cebos como USB infectados.
- » **Botnet:** Red de dispositivos infectados controlados remotamente.
- » **Certificado digital:** Documento digital que autentica una identidad.
- » **Checkmk:** Sistema de monitorización basado en Nagios.
- » **Cifrado:** Proceso de codificación de datos para protegerlos.
- » **Clave asimétrica:** Usa un par de claves (pública y privada) para cifrado/descifrado.
- » **Clave simétrica:** Usa la misma clave para cifrar y descifrar.
- » **DHCP:** Protocolo que asigna direcciones IP automáticamente.
- » **Firewall (cortafuegos):** Sistema de defensa que filtra el tráfico de red según reglas definidas.
- » **Firma electrónica:** Método legal para validar documentos y transacciones electrónicas.
- » **Hoax:** Mensajes falsos difundidos en cadena.
- » **IDS (Intrusion Detection System):** Sistema que detecta accesos o actividades no autorizadas.
- » **IP (Internet Protocol):** Dirección única que identifica un dispositivo en una red.
- » **IPS (Intrusion Prevention System):** Sistema que bloquea automáticamente ataques detectados.
- » **LAN (Local Area Network):** Red de ámbito local.
- » **MAC (Media Access Control):** Identificador físico único de una tarjeta de red.
- » **Malvertising:** Publicidad en línea que contiene código malicioso.

- » **Nagios/Zabbix/Prometheus/Grafana/Monit:** Herramientas de monitorización de sistemas y redes.
- » **NAT:** Traducción de direcciones privadas a públicas.
- » **Netfilter/iptables/nftables:** Sistemas de filtrado y control de tráfico en Linux.
- » **nmap:** Herramienta para escanear redes y puertos y detectar sistemas operativos.
- » **PGP/S-MIME:** Tecnologías de cifrado para correos electrónicos.
- » **Pharming:** Manipulación del DNS para redirigir a sitios falsos.
- » **Phishing:** Suplantación de identidad digital para robar información.
- » **Pretexting:** Ataques basados en identidades o historias falsas.
- » **Puertos:** Canales lógicos usados por los protocolos para comunicarse (p. ej.: HTTP = 80, HTTPS = 443).
- » **Quid pro quo:** Engaños que ofrecen algo a cambio de información.
- » **Scam baiting:** Engañar activamente a los estafadores para exponerlos.
- » **SHA-256:** Algoritmo criptográfico para verificar la integridad de archivos.
- » **Shoulder Surfing:** Observar físicamente a alguien para robar datos.
- » **SLA (Service Level Agreement):** Acuerdo de nivel de servicio.
- » **Smishing:** Phishing por SMS.
- » **Sniffer:** Herramienta que captura el tráfico de red (puede ser legítimo o malicioso).
- » **SNMP:** Protocolo para monitorizar y gestionar dispositivos de red.
- » **Spam:** Correos o mensajes electrónicos no solicitados.
- » **Spear Phishing:** Phishing personalizado hacia individuos específicos.
- » **SSID:** Nombre que identifica a una red wifi.
- » **syslog:** Sistema de gestión de logs en Unix/Linux.
- » **Vishing:** Phishing por llamadas telefónicas.

- » **VPN (red privada virtual):** Conexión segura cifrada a través de Internet.
- » **WAN (Wide Area Network):** Red de área amplia (como Internet).
- » **Whaling:** Phishing dirigido a altos cargos.
- » **Wireshark:** Sniffer de red ampliamente usado para analizar el tráfico.

Bibliografía

Agencia Española de Protección de Datos (AEPD). *Guía de seguridad de datos personales en la nube*. Disponible en: <https://www.aepd.es/>

Barrett, D. Silverman, R. y Byrnes, R. (2005). *SSH, The Secure Shell: The Definitive Guide*. O'Reilly Media.

Bjorge, M. (2022). *Wireshark for Security Professionals*. Wiley.

Gordon, A. (2020). *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. Nmap Project.

Hadnagy, C. (2018). *Social Engineering: The Science of Human Hacking*. Wiley.

Jakobsson, M. y Myers, S. (2006). *Phishing and Countermeasures: Understanding the Increasing Problem of Electronic Identity Theft*. Wiley.

Kurose, J. F. y Ross, K. W. (2021). *Computer Networking: A Top-Down Approach*. Pearson.

Northcutt, S. y Novak, J. (2002). *Network Intrusion Detection*. New Riders Publishing.

Parlamento Europeo. (2014). *Reglamento (UE) n.º 910/2014 eIDAS, sobre identificación electrónica y servicios de confianza*. Disponible en: <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32014R0910>

Scarfone, K. y Mell, P. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)*. NIST Special Publication 800-94. Disponible en: <https://www.nist.gov/publications/guide-intrusion-detection-and-prevention-systems-idps>

Schneier, B. (2015). *Applied Cryptography: Protocols, Algorithms, and Source Code in C*. Wiley.

Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice*. Pearson.

Tanenbaum, A. S. y Wetherall, D. J. (2013). *Computer Networks*. Pearson.

Turnbull, J. (2014). *The Art of Monitoring*. Turnbull Press.

UAX FP